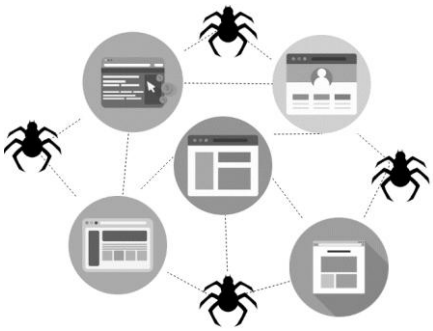
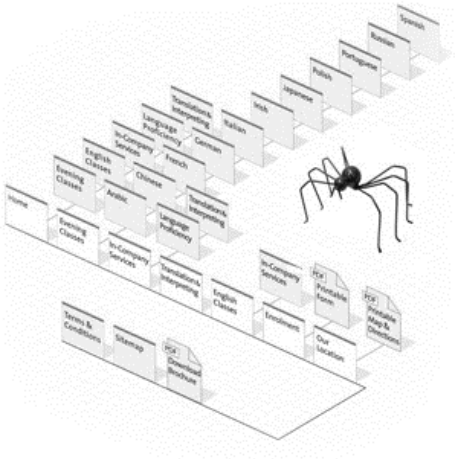
3. INVESTIGACIÓN MEDIANTE BUSCADORES

Los buscadores son sistemas informáticos que tienen como objetivo la recopilación automática de nuevos sitios mediante rastreadores webs para explorar de forma automática Internet y realizar diferentes acciones sobre su base de datos interna. Este proceso de búsqueda se compone de las siguientes tres fases:

1. **Rastrear**. Los rastreadores webs (denominados también crawlers, spiders o bots) utilizados por el buscador exploran Internet en búsqueda de nuevas páginas y/o actualizaciones de las que hayan sido previamente rastreadas. El método más habitual para llevar a cabo tal proceso consiste en seguir los enlaces presentes en las páginas que ya contiene su base de datos. De este modo, el buscador guardará las direcciones URL de las páginas recolectadas dentro de una lista exhaustiva que irá consultando cada cierto tiempo.



2. **Indexar**. El buscador visita las páginas identificadas, a través de sus direcciones URL, con el fin de analizar su contenido, imágenes y archivos de vídeo. Toda esta información se almacena en el índice del buscador (una enorme base de datos, almacenada en distintos servidores).



La primera operación que realizan los rastreadores web al acceder a un sitio web en particular, es consultar el archivo robots.txt, un estándar de exclusión de robots que se suele utilizar para indicarle a los buscadores a que parte de su sitio web tienen acceso o bien que ruta de este está desactivada para su indexación. En la Imagen 62 puede verse el archivo robots.txt de la web del campus y que rutas estas denegadas para no ser indexadas.

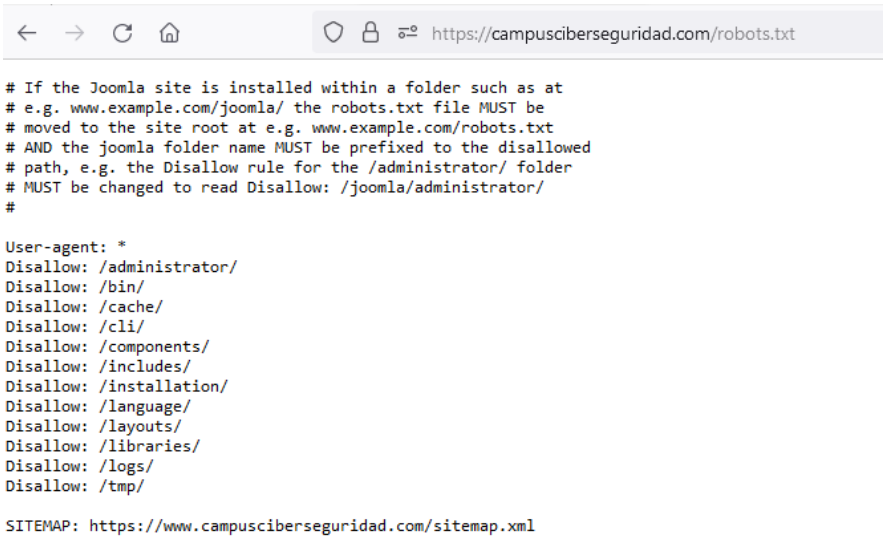


Imagen 62. Archivo robots.txt

3. **Mostrar resultados**. Por último, cuando un usuario realiza una búsqueda especifica en el buscador, este intenta mostrar los resultados más pertinentes para él. Por ello, los resultados que aparecen para el usuario están vinculados estrechamente a varios factores, tales como su ubicación, el idioma, dispositivo

empleado y/o su histórico de consultas. En este proceso, el buscador hace uso de algoritmos internos diseñados para optimizar el funcionamiento del propio buscador.



Los buscadores los podemos clasificar de más genéricos a más específicos en función del tipo de datos que podamos llegar a obtener. La clasificación es la siguiente:

- Buscadores genéricos
- Buscadores especializados
- Buscadores de imágenes
- Otros tipos de buscadores

3.1. BUSCADORES GENÉRICOS

Los buscadores genéricos son aquellos que todo el mundo suele usar en su día a día, como, por ejemplo, Google o Bing. Su objetivo es rastrear e indexar la máxima información posible.

A la hora de realizar búsquedas en los propios buscadores, podemos utilizar diferentes tipos de técnicas denominadas **dorks**. Dicho término hace referencia a una serie de comandos u operadores de búsqueda disponibles en algunos buscadores, que permiten acotar y especificar la información en las consultas generadas; de este modo, a través de este tipo de consultas, se puede llegar incluso a obtener información sensible expuesta, previamente indexada. El término dorks apareció en 2002 de la mano del especialista de

seguridad Johnny Long, el cual se dio cuenta que podía descubrir vulnerabilidades en distintos sitios webs y acceder a contenido sensible.

A su vez, el uso de estos operadores, como técnica para extraer información sensible a través de Google, se conoce habitualmente como Google Hacking o Google Dorks; de forma análoga, también se puede hablar de los términos Bing Hacking, al hacer uso de esta técnica en estos buscadores.

3.1.1. GOOGLE DORKS

Google es uno de los buscadores más populares y ampliamente conocido por la gran mayoría de usuarios, siendo el primero de la lista en ser utilizado cuando tenemos que buscar cualquier información en Internet.

Con el objetivo de que se dispongan de las herramientas adecuadas para poder construir consultas más complejas combinando diferentes operadores entre sí, se facilita un listado con todos los dorks y una breve descripción (ver Tabla 1).

Dork	Descripción
"Búsqueda exacta"	Buscar frase exacta utilizando las comillas (" ")
-	Eliminar de los resultados de búsqueda las páginas que mencionan un término determinado
+	Obligar a Google a devolver palabras comunes que normalmente se descartarían
OR	Buscar un término de búsqueda dado u otro término
site:	Buscar por un dominio dado
filetype:	Buscar por un determinado tipo de fichero

ext:	Buscar por un determinado tipo de extensión de fichero
intitle:	Buscar sitios con la palabra clave objetivo en el título de la página web
inurl:	Buscar sitios con la palabra clave objetivo en la URL
intext:	Buscar sitios con la palabra clave objetivo en el contenido de una página web
inarchor:	Buscar sitios con la palabra clave objetivo en enlaces que apunten a ellos
cache:	Mostrar la cache más reciente de una página web
link:	Buscar sitios web que enlazan al dominio objetivo
related:	Buscar sitios web similares al dominio objetivo

Tabla 1. Listado de operadores básicos de Google

Ahora que ya se conocen los operadores básicos, vamos a ir construyendo diferentes dorks más complejas.

- Buscar la palabra clave "intranet" dentro de las URL de una página web, donde en dichos resultados filtre por el tipo de fichero ".doc" y sobre los resultados realice una búsqueda de la palabra clave "confidential" dentro del contenido del sitio web.

```
inurl:intranet filetype:doc intext:confidential
```

En la Imagen 63 puede comprobarse el resultado de la dork, devolviendo un total de *207 resultados*, todos ellos permitiendo la descarga de un documento .doc.

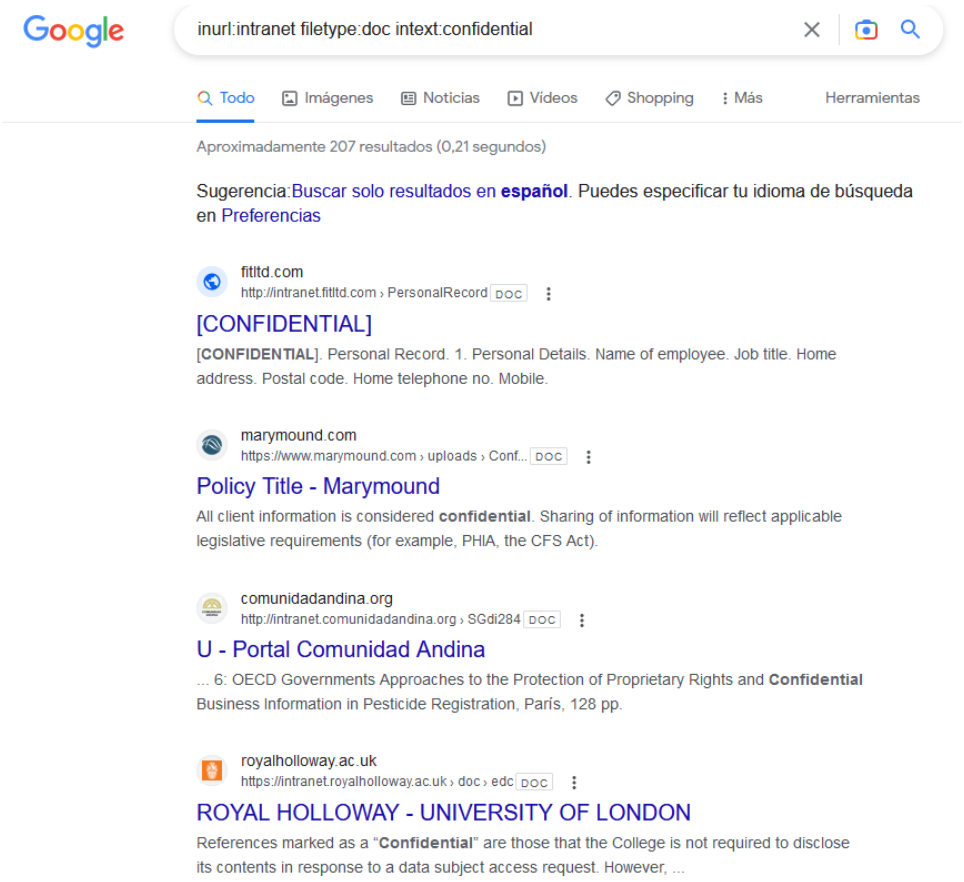


Imagen 63. Buscando documentos confidenciales

- Buscar la frase clave "Live view / – AXIS" dentro del título de una página web con el objetivo de detectar sitios web relacionados con cámaras web de la marca AXIS y excluyendo los resultados que procedan de Twitter.

```
intitle:"Live view / – AXIS" -site:twitter.com
```

En la Imagen 64 puede comprobarse el resultado de la dork, devolviendo un total de *1.890 resultados* relacionados con cámaras web AXIS, permitiendo el acceso a

sitios web donde se puede visualizar su contenido. Un ejemplo de ello puede verse en la Imagen 65.

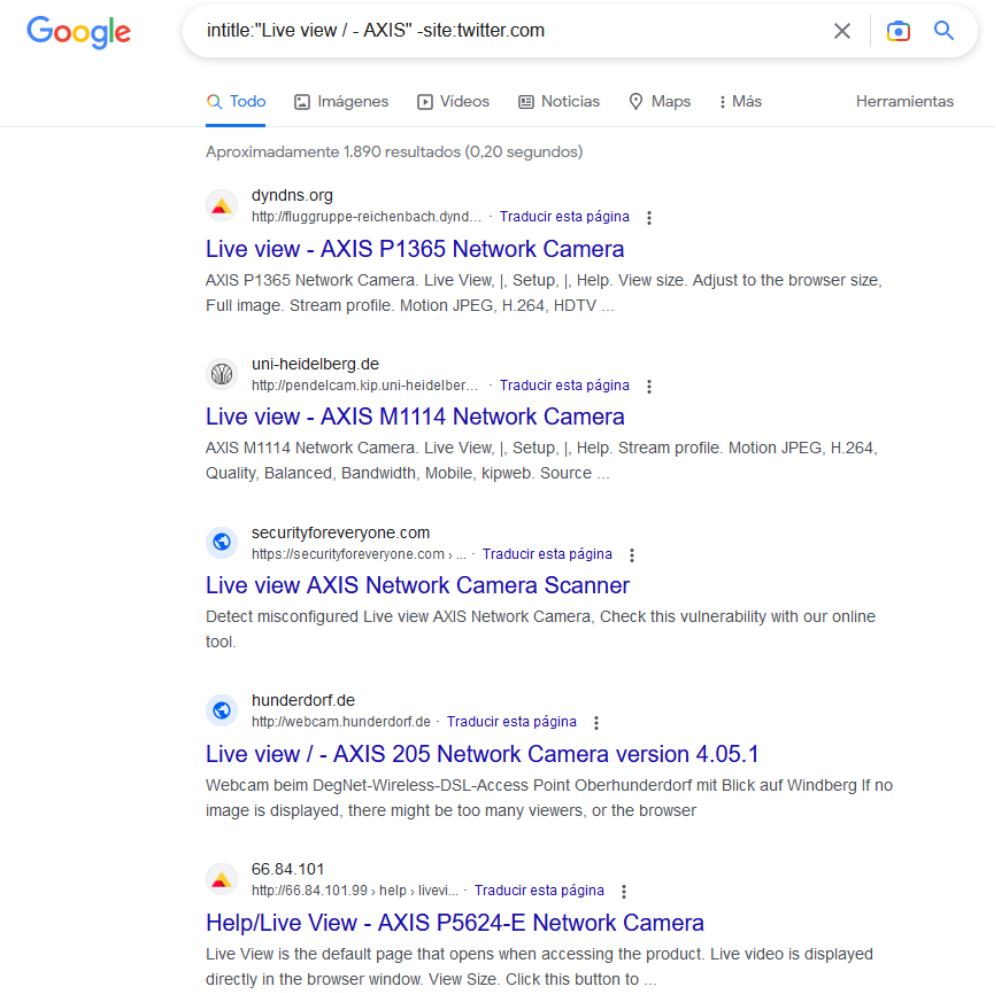


Imagen 64. Buscar cámaras web de AXIS excluyendo resultados de Twitter

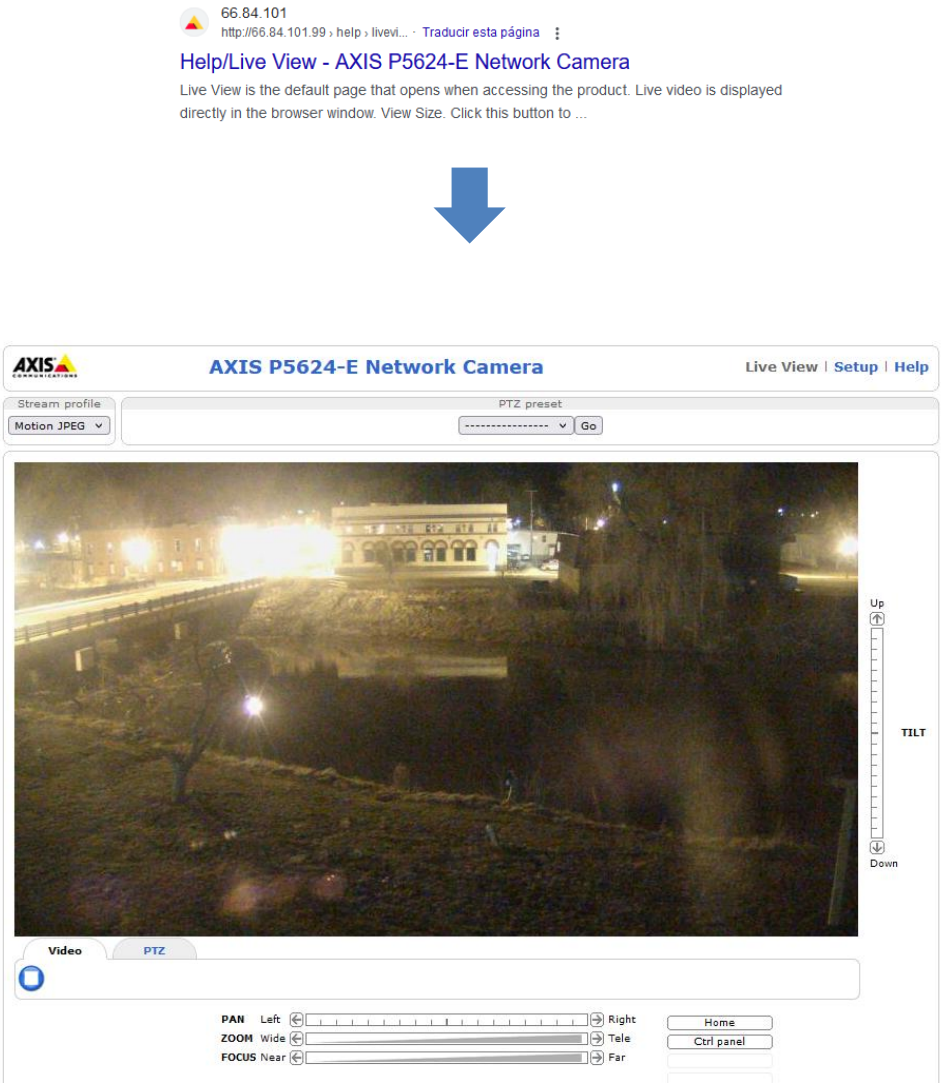


Imagen 65. Acceso público y sin login hacia un resultado de Cámara AXIS de la Imagen64

- Buscar la frase clave "index of" dentro del título de una página web con el objetivo de detectar sitios web relacionados con directorios de archivos público y sobre sus resultados filtrar por la frase clave "//whatsapp/" para localizar posibles archivos compartidos por Whatsapp.

intitle:"index of" **inurl:** "//whatsapp/"

En la Imagen 66 puede comprobarse el resultado de la dork, devolviendo un total de *1.400 resultados* relacionados con directorios de archivos y Whatsapp. En la Imagen 67 puede visualizarse el contenido uno de los resultados obtenidos de la Imagen 66.

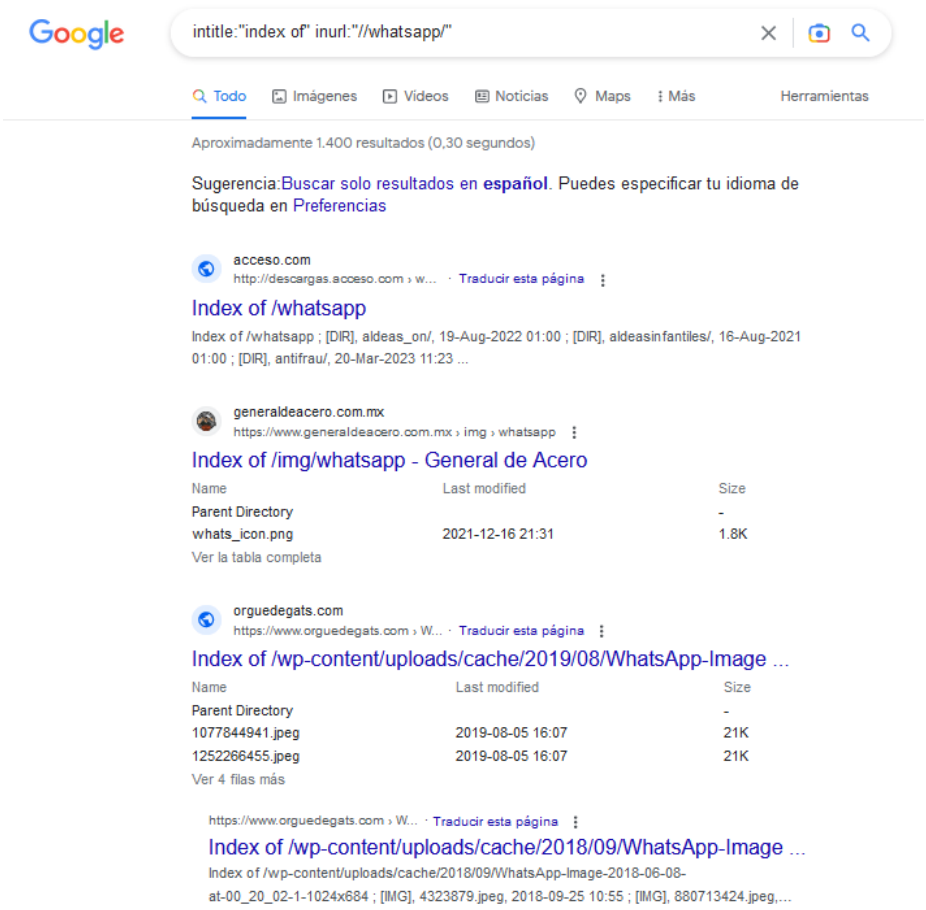


Imagen 66. Buscar directorios de archivos relacionados con Whatsapp

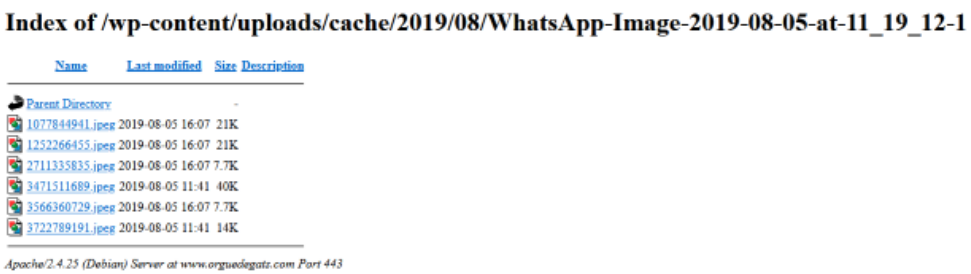


Imagen 67. Acceso a uno de los resultados de la Imagen 65

- Obtener todos los resultados del sitio web JustPaste y del sitio web Pastebin, filtrando los resultados con la combinatoria de buscar la palabra clave "#hacktivism" dentro del contenido de los dos sitios web o la palabra clave "#anonymous" dentro de su contenido. Con esta consulta obtendremos todas las coincidencias de los dos hashtags por separado dentro de los sitios pastes de JustPaste y Pastebin.

```
site:justpaste.it | site:pastebin.com intext:"#hacktivism" | intext:"#anonymous"
```

En la Imagen 68 puede comprobarse el resultado de la dork, devolviendo un total de *316 resultados*. En la Imagen 69 puede visualizarse el contenido de los dos primeros resultados obtenidos de la Imagen 68.

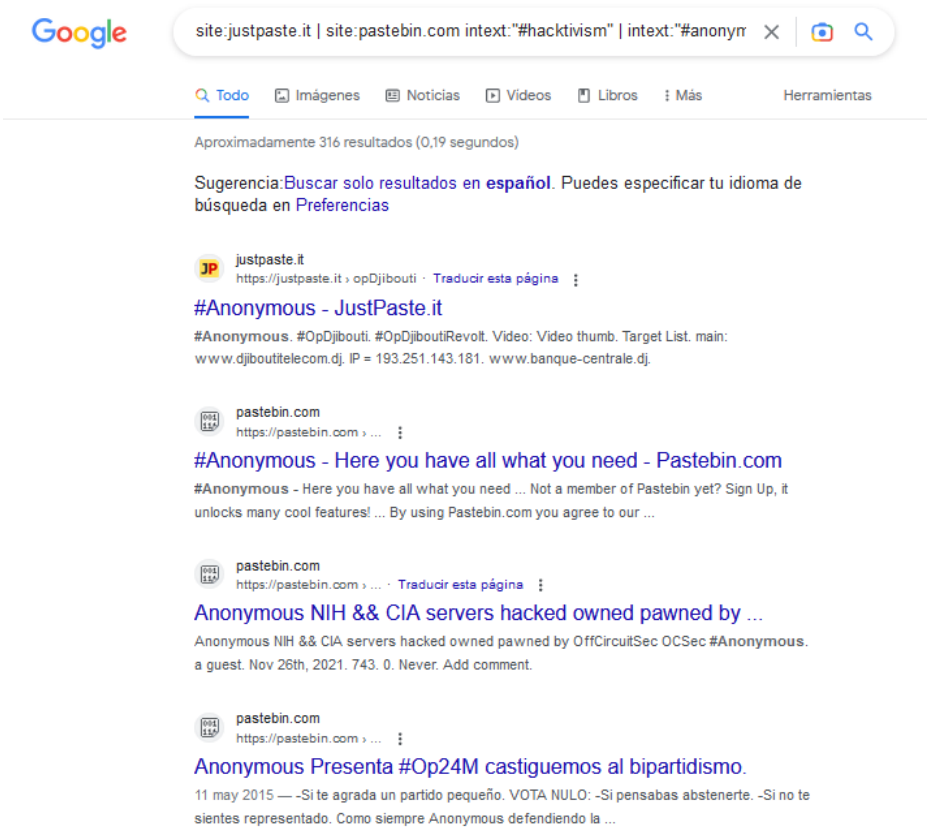


Imagen 68. Buscar coincidencias de los hashtags anonymous y hacktivism dentro de los dos sitios de pastes

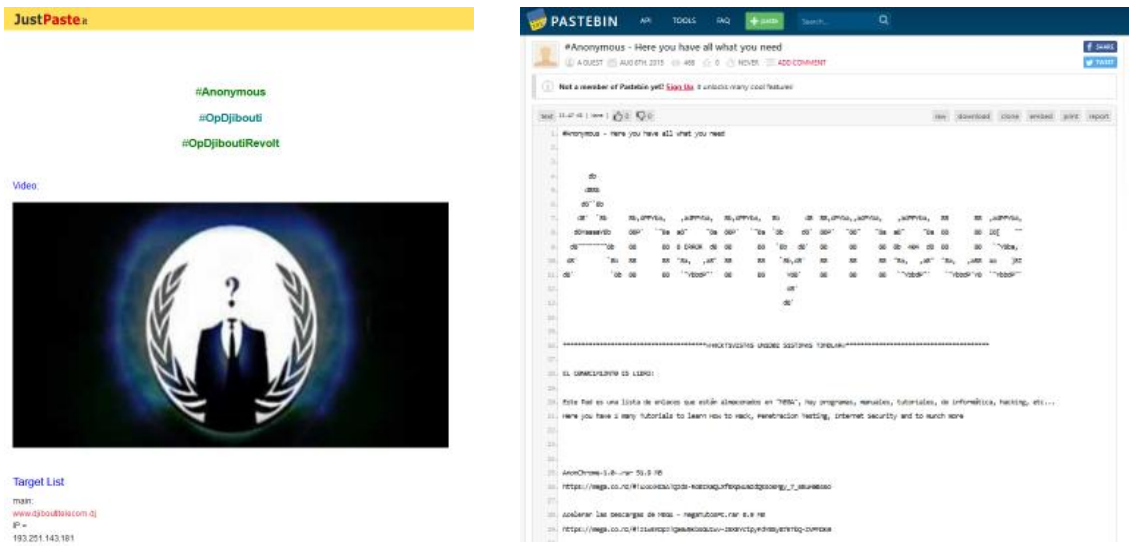


Imagen 69. Resultados de JustPaste y Pastebin

- Buscar dentro del sitio web de Telegram cualquier coincidencia de la palabra clave "ransomware" o "#ransomware". Este tipo de búsqueda nos va a ayudar por un lado a localizar URLs hacia canales y/o grupos de Telegram y por otro en el caso de los canales ver un previo del mismo directamente.

```
site:"t.me" ransomware|"#ransomware"
```

En la Imagen 70 puede comprobarse el resultado de la dork, devolviendo un total de *239 resultados*.

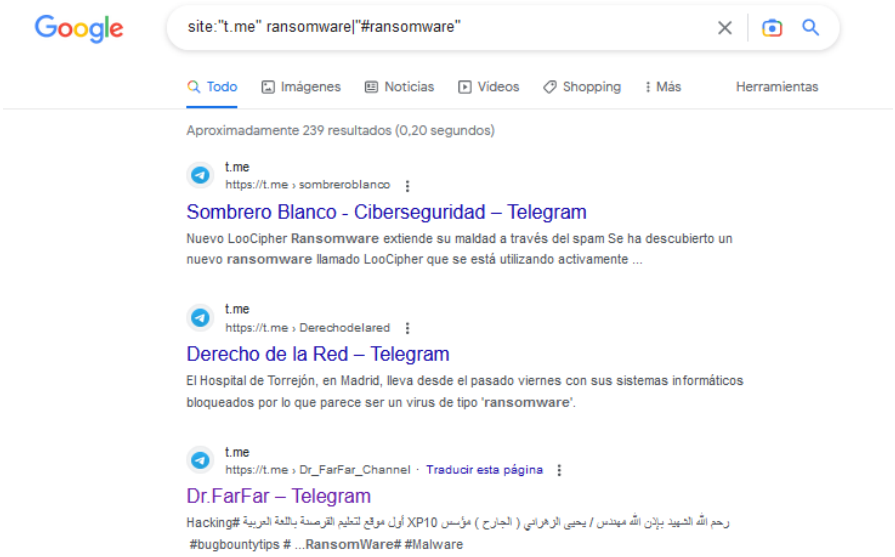


Imagen 70. Resultado obtenidos buscando palabras clave en Telegram

En la Imagen 71 puede visualizarse el contenido de los dos primeros resultados obtenidos de la Imagen 70.





Imagen 71.Preview del canal descubierto de Telegram mediante Google Dorks

Google cuenta con un buscador avanzado en el que podemos apoyarnos para preparar las diferentes consultas utilizando una interfaz más intuitiva. Disponéis del enlace de dicho buscador aquí: https://www.google.es/advanced_search. En la Imagen 72 se puede ver el buscador avanzado utilizando una consulta concreta.

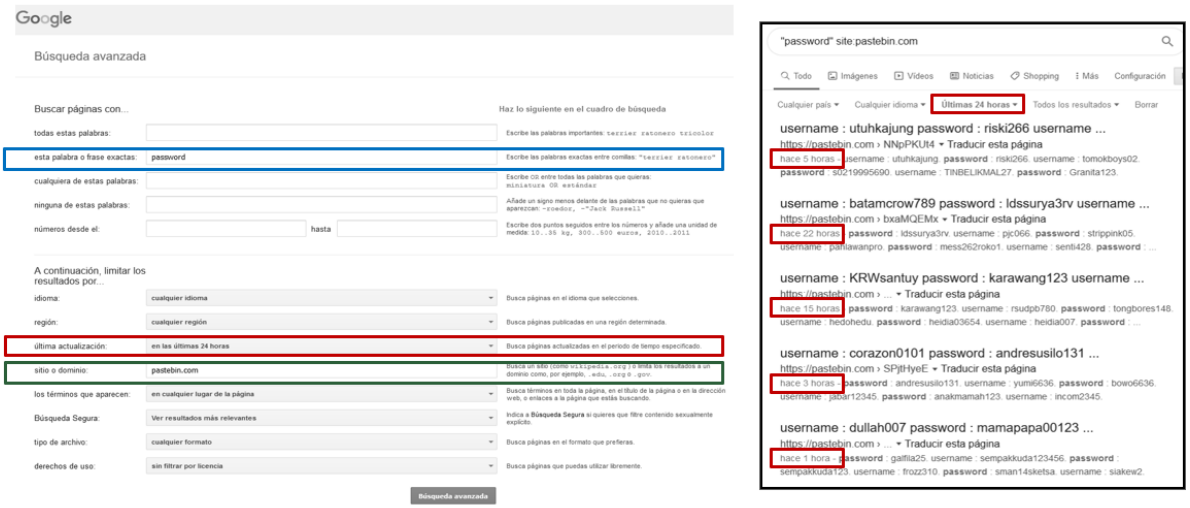


Imagen 72. Buscador avanzado de Google

En el caso de que queramos descubrir más tipologías de dorks podemos encontrar en Internet una base de datos con multitud de dorks llamada **Google Hacking Database (GHDB),** alimentada de información por parte de investigadores que comparten sus propias dorks. El acceso está disponible en el siguiente enlace: https://www.exploit-db.com/google-hacking-database.

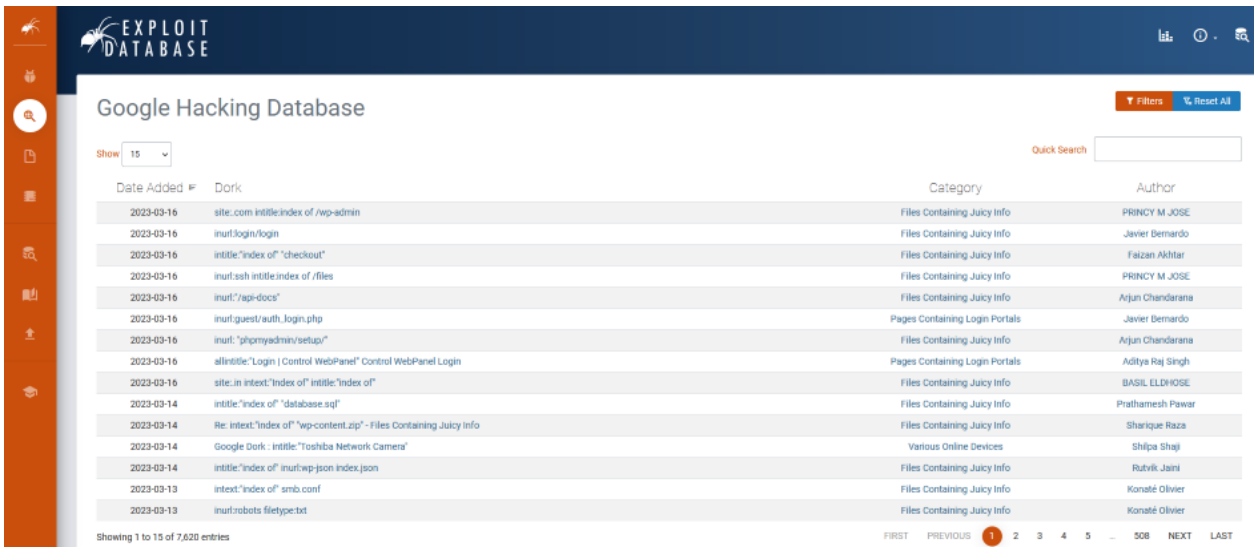


Imagen 73. Sitio web de Exploit Database

Exploit Database dispone de una serie de filtros que podemos utilizar para localizar determinadas Google Dorks buscando por categorías. Algunas de las categorías que podemos encontrarnos son las siguientes:

- Ficheros que contengan nombres de usuario o contraseñas
- Información sensible
- Detección de servidores web
- Ficheros y servidores vulnerables
- Mensajes de error
- Páginas que contienen portales de login

3.1.1.1. GOOGLE ALERTS

Hasta ahora se ha mostrado la potencia de las diferentes búsquedas que podemos realizar utilizando el motor de Google, pero solo se tratan de consultas manuales lo que implica una clara desventaja en cuanto a tiempos de ejecución de manera individual. Aquí entra en juego uno de los servicios que ofrece Google dentro de su ecosistema, las **Google Alerts**.

Google Alerts permite planificar diferentes consultas y realizar una monitorización de estas por medio de un panel centralizado donde hacer el seguimiento, donde lo único que necesitaremos será disponer de una cuenta de Google para poder loguearnos en su plataforma. Su enlace de acceso es el siguiente: https://www.google.com/alerts.

En el momento que ya se haya accedido a la plataforma de Google Alerts, se podrá ir añadiendo las diferentes Google Dorks de manera individual. Por cada alerta seleccionaremos el tipo de Fuente (automático, noticias, blogs, web, video, libros, foros o finanzas), el idioma, la región, la cantidad de resultados a recibir (Todos o solo los mejores) y porque vía recibir los resultados (feed RSS o correo electrónico).

En la Imagen 74 puede apreciarse justo lo mencionado, donde se ha elegido recibir los resultados vía Feed RSS ya que nos puede ayudar, si así lo deseamos, a automatizar el proceso y almacenar los resultados en una base de datos.

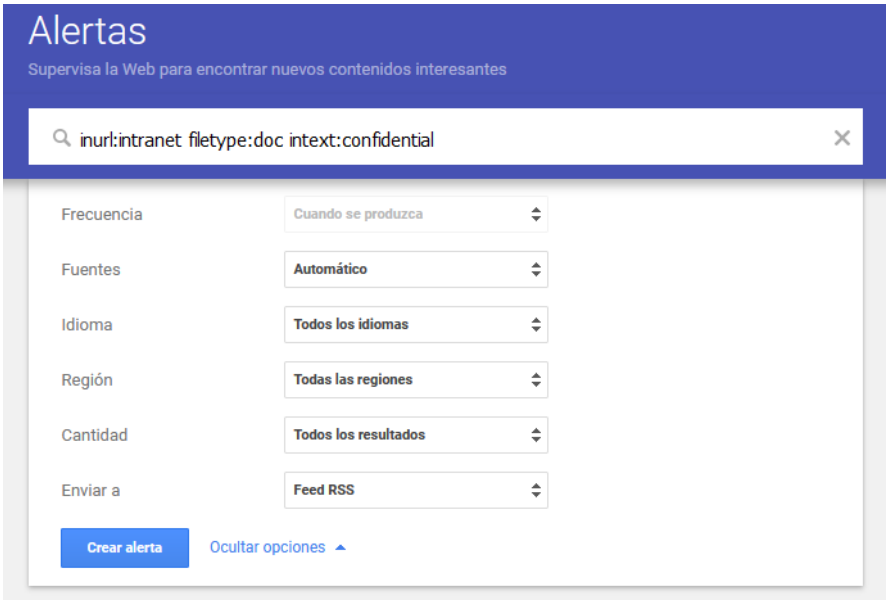


Imagen 74. Creación de una dork dentro de Google Alerts

En la Imagen 75 pueden visualizarse todas las alertas que se tienen cargadas y configuradas, las cuales podrán ser eliminadas o editadas. Si se presta atención a las alertas hay algunas que aparece un logo y en otros no, esto hace referencia a las alertas que hayan sido configuradas como RSS, en el caso de aparecer el logo .

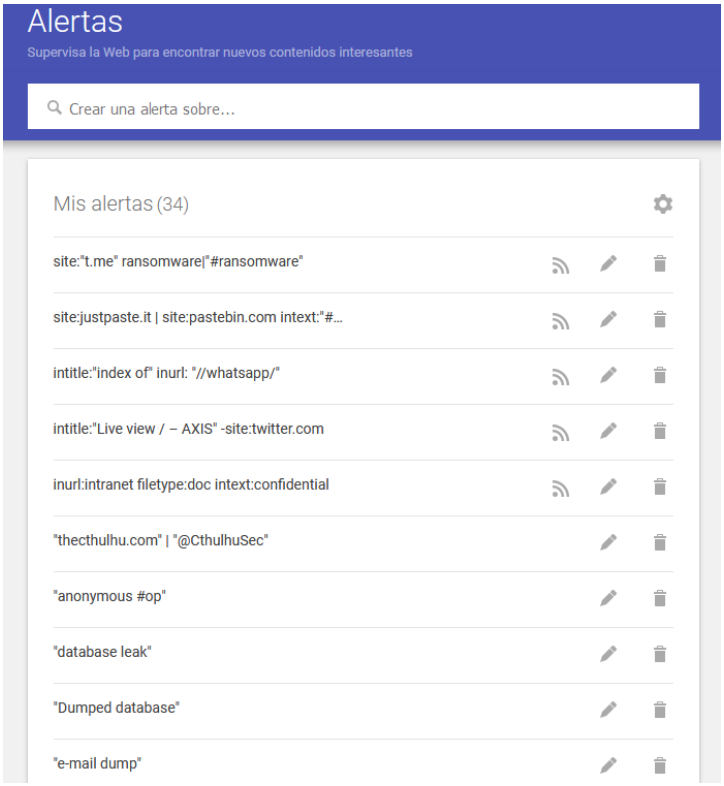


Imagen 75. Panel de control de las Google Alerts

3.1.1.2. CSE DE GOOGLE

Google nos permite crear buscadores personalizados, a través de su servicio "**Custom Search Engine (CSE)"**, utilizando las fuentes que tengamos categorizadas como fiables y excluyendo así el resto. De este modo, a través del motor de búsqueda de Google, podremos crear un buscador totalmente adaptado a nuestras necesidades.

Esto significa que obtendremos información exclusivamente de las fuentes que le indiquemos en la configuración. CSE está limitado a 100 resultados únicamente, pero si añadimos búsquedas muy específicas no será un problema.

Tal como ocurre con Google Alerts, necesitaremos una cuenta de Google para poder operar con CSE. El enlace de acceso es el siguiente: https://programmablesearchengine.google.com.

3.1.1.3. CREAR UN BUSCADOR CON CSE PARA CONSULTAR FUENTES DE INTELIGENCIA

Vamos a crear un buscador enfocado en obtener únicamente resultados centrándonos en una serie de fuentes de Inteligencia. Para ello nos vamos a focalizar en las siguientes:

ginseg.com
ccn-cert.cni.es
incibe.es
securelist.com
kaspersky.com
symantec.com
bellingcat.com
intel471.com
flashpoint-intel.com
unit42.paloaltonetworks.com

Lo primero a realizar será acceder al portal de CSE e indicarle que se desea crear un nuevo buscador o bien acceder directamente mediante el siguiente enlace: https://programmablesearchengine.google.com/controlpanel/create.

En la Imagen 76 puede visualizarse el panel relacionado con la creación del buscador. En el mismo le facilitamos un nombre para el buscador (Buscador de fuentes de Inteligencia), buscamos en las fuentes especificas citadas anteriormente y habilitamos dos tipos de configuraciones (búsqueda por imágenes y búsqueda segura).

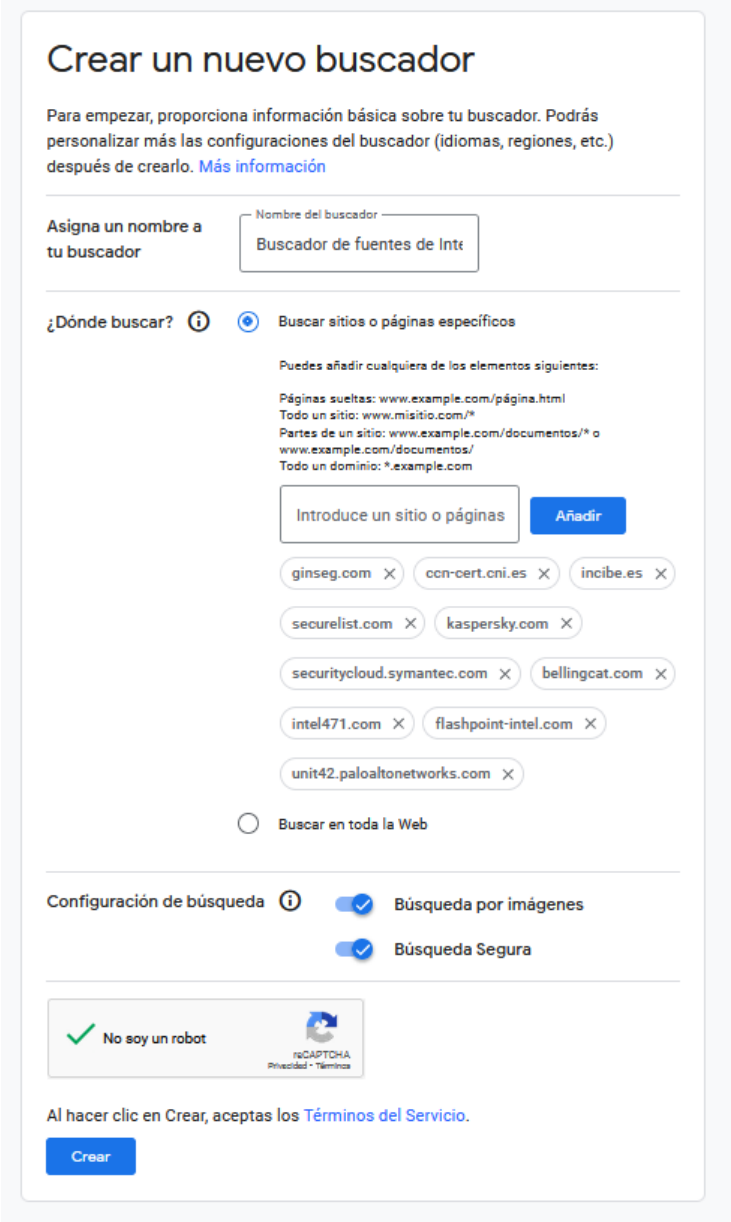


Imagen 76. Creación de CSE

En este momento ya tendríamos creado nuestro primer buscador, pero ahora mismo está configurado por defecto. Si accedemos a su configuración podremos parametrizarlo a nuestro gusto. En la Imagen 77 puede visualizarse la configuración por defecto.

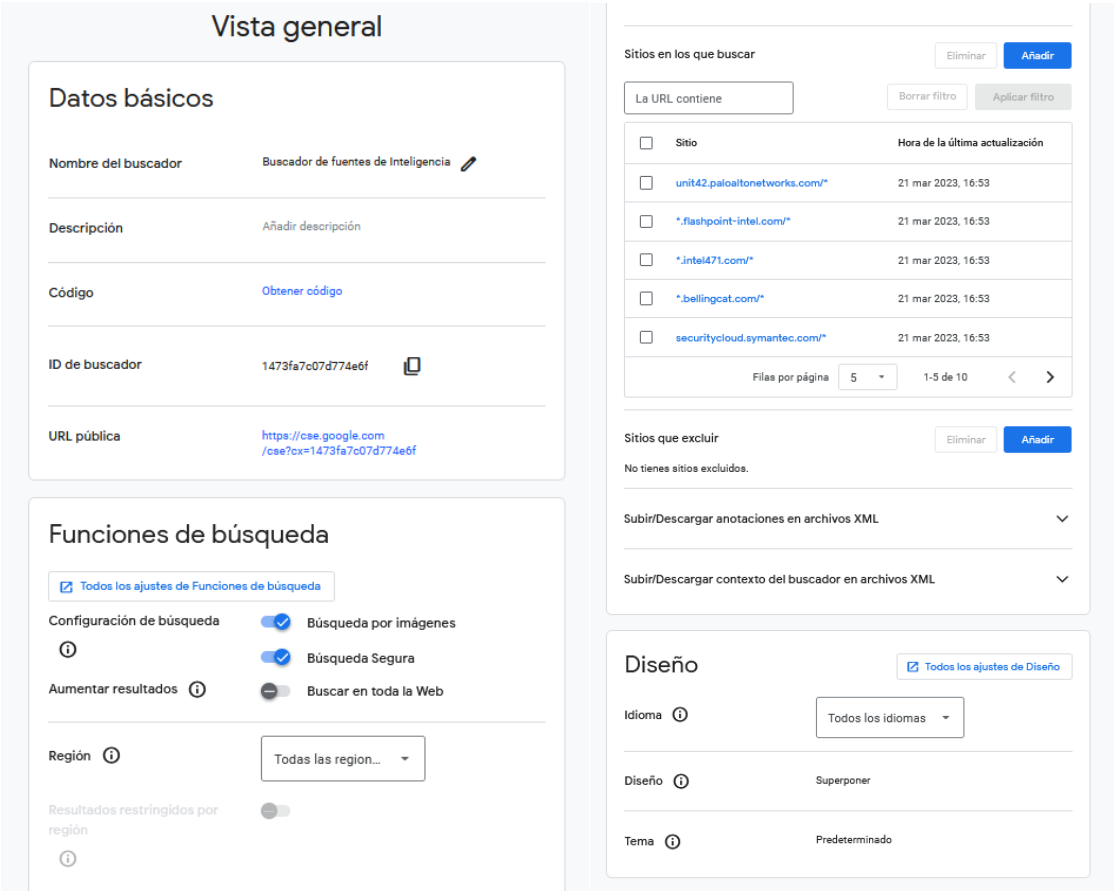


Imagen 77. Configuración por defecto del buscador

En la parte de la izquierda se dispone de un menú de configuración del propio buscador, donde vamos a poder parametrizar el mismo con temas de diseño, añadir filtros en las búsquedas, etc. En la Imagen 78 puede visualizarse dicho menú.

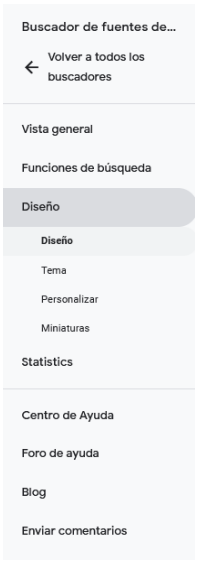


Imagen 78. Menú de parametrización del buscador

En la Imagen 79 puede visualizarse las opciones seleccionadas en cuanto al diseño y el tema elegido para el buscador.

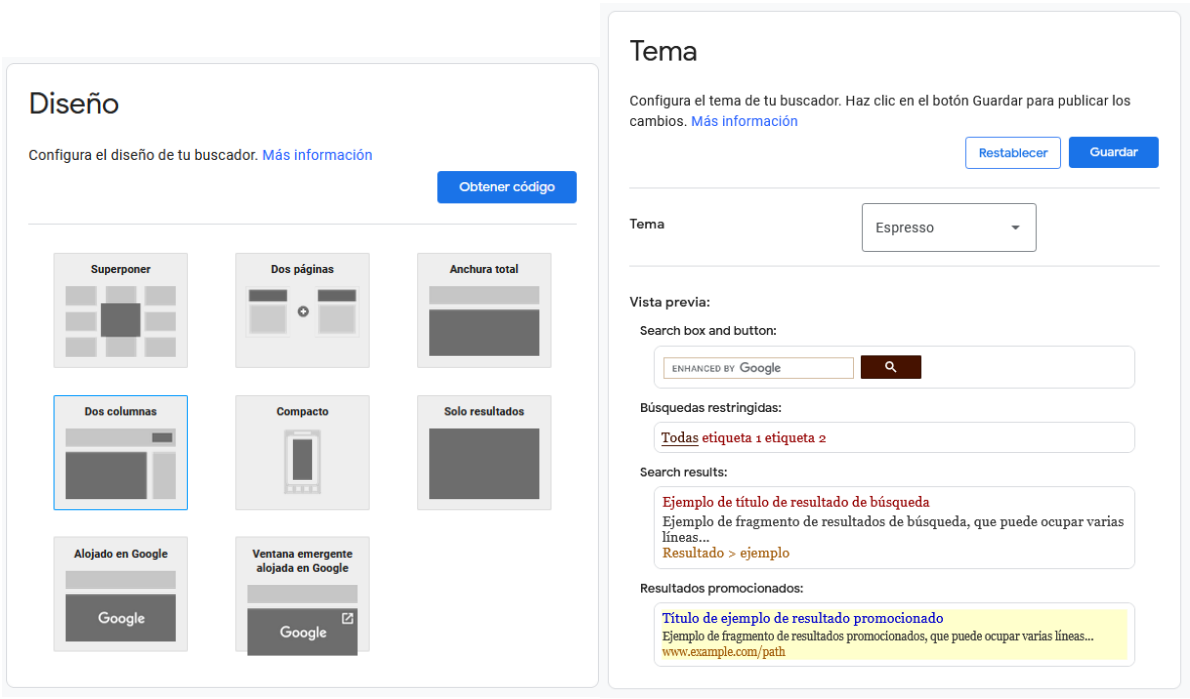


Imagen 79. Parametrización del diseño del buscador

En la opción del menú de "Funciones de búsqueda" podemos parametrizar por búsquedas restringidas o añadir palabras clave para su monitorización (ver Imagen 80).

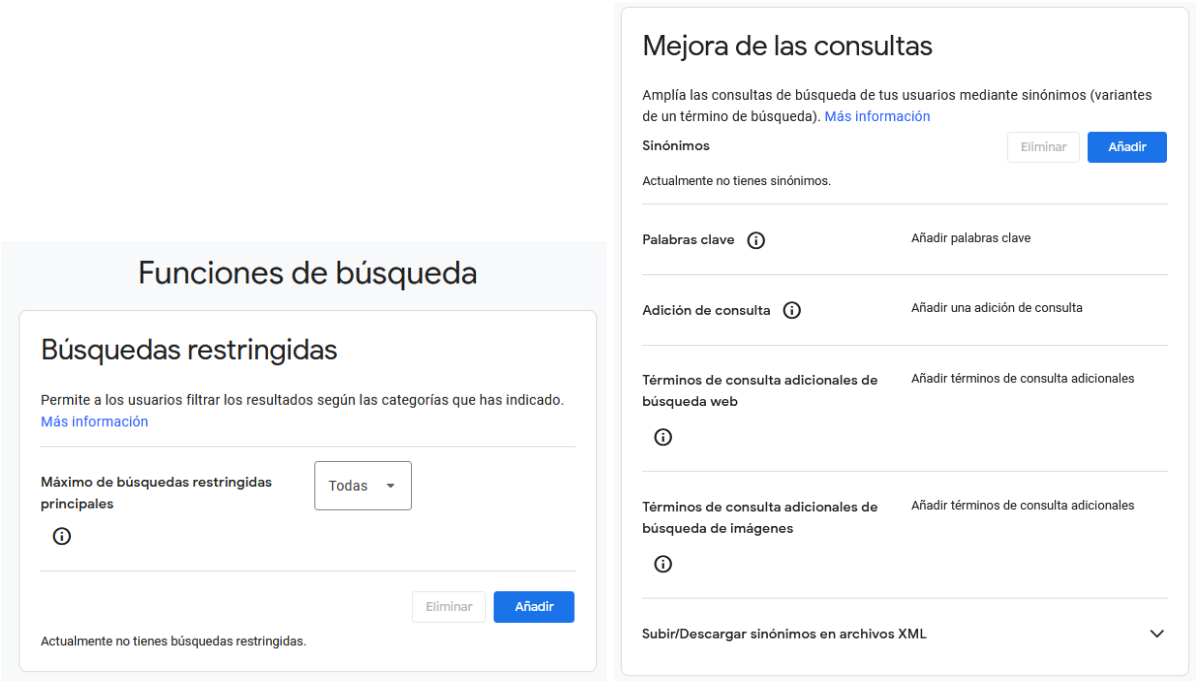


Imagen 80. Parametrización de funciones de búsqueda en el buscador de CSE.

Ahora ya tendríamos listo nuestro buscador parametrizado a nuestras necesidades y podríamos acceder a él con el enlace público que puede verse en la Imagen 81.

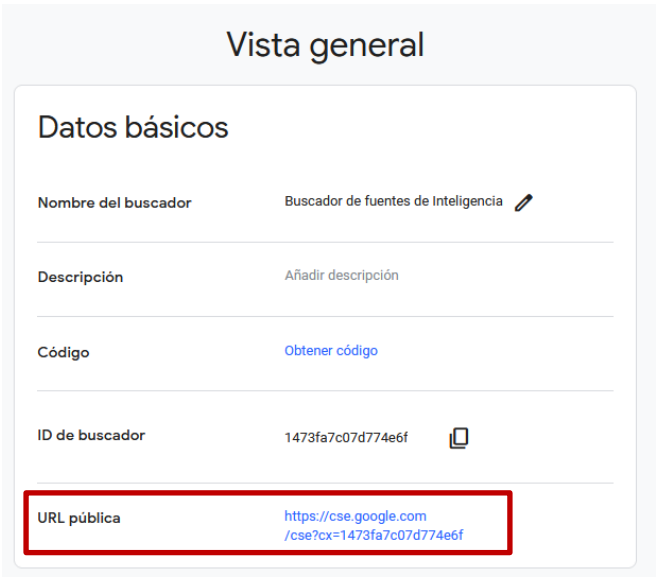


Imagen 81. Localización de URL pública del buscador

En la Imagen 82 podemos visualizar el buscador CSE creado con una consulta sobre ransomware en las fuentes de Inteligencia indicadas en su parametrización.



Imagen 82. Resultados de consulta con el buscador CSE creado

3.1.1.4. CREAR UN BUSCADOR CON CSE PARA MONITORIZAR REDES SOCIALES

Vamos a crear ahora un buscador enfocado en obtener información consultando redes sociales y Telegram, siendo en líneas generales las siguientes fuentes a añadir:

twitter.com
facebook.com
instagram.com
linkedin.com
t.me

Lo primero a realizar será acceder al portal de CSE e indicarle que se desea crear un nuevo buscador o bien acceder directamente mediante el siguiente enlace: https://programmablesearchengine.google.com/controlpanel/create. En la Imagen 83 puede visualizarse el panel relacionado con la creación del buscador. En el mismo le facilitamos un nombre para el buscador (Buscador de redes sociales), buscamos en las

fuentes especificas citadas anteriormente y habilitamos dos tipos de configuraciones (búsqueda por imágenes y búsqueda segura).

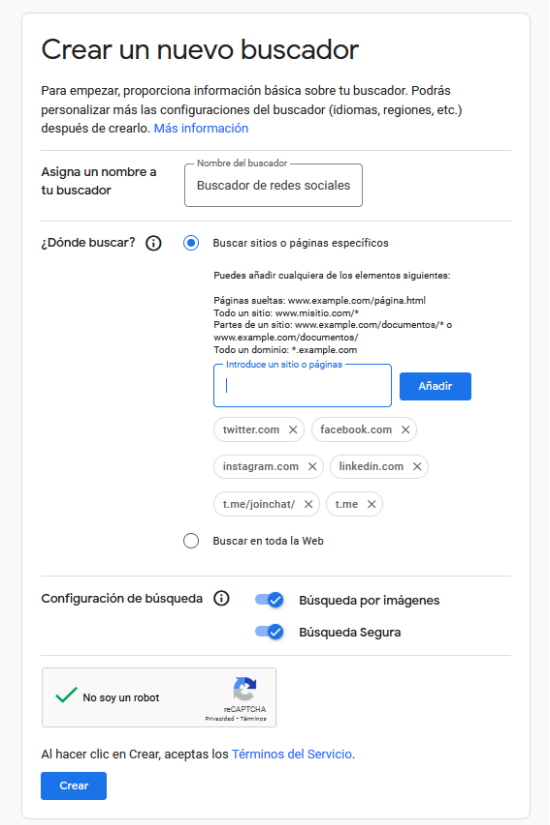


Imagen 83. Creación del buscador CSE enfocado en redes sociales

En este momento ya tendríamos creado nuestro segundo buscador, pero si recordamos, en el anterior buscador recibíamos todos los resultados a nivel general sin categorizar por tipo de fuentes y en algunos casos puede ser interesante disponer de una separación. Por este motivo vamos a personalizar el buscador para que separe los resultados por cada una de las fuentes. En la Imagen 84 accedemos al menú “Funciones de búsqueda” y en “Búsquedas restringidas” y seleccionamos el número máximo de búsquedas restringidas, en nuestro caso indicamos 5 (uno por cada fuente).



Imagen 84. Configuración de las búsquedas restringidas

Lo siguiente a realizar será añadir el nombre de la búsqueda restringida y asociarlo con la fuente. En la Imagen 85 puede verse la asociación de las fuentes de Twitter y Facebook con el nombre restringido relacionado.

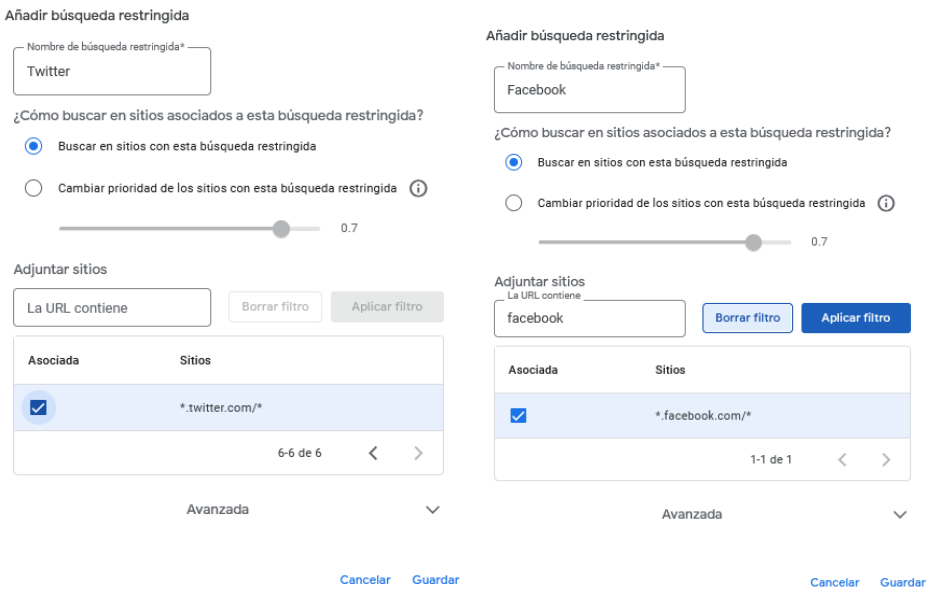


Imagen 85. Configuración de la búsqueda restringida de Twitter y Facebook

En la Imagen 86 puede verse la asociación de las fuentes de LinkedIn, Instagram y Telegram con el nombre restringido relacionado.

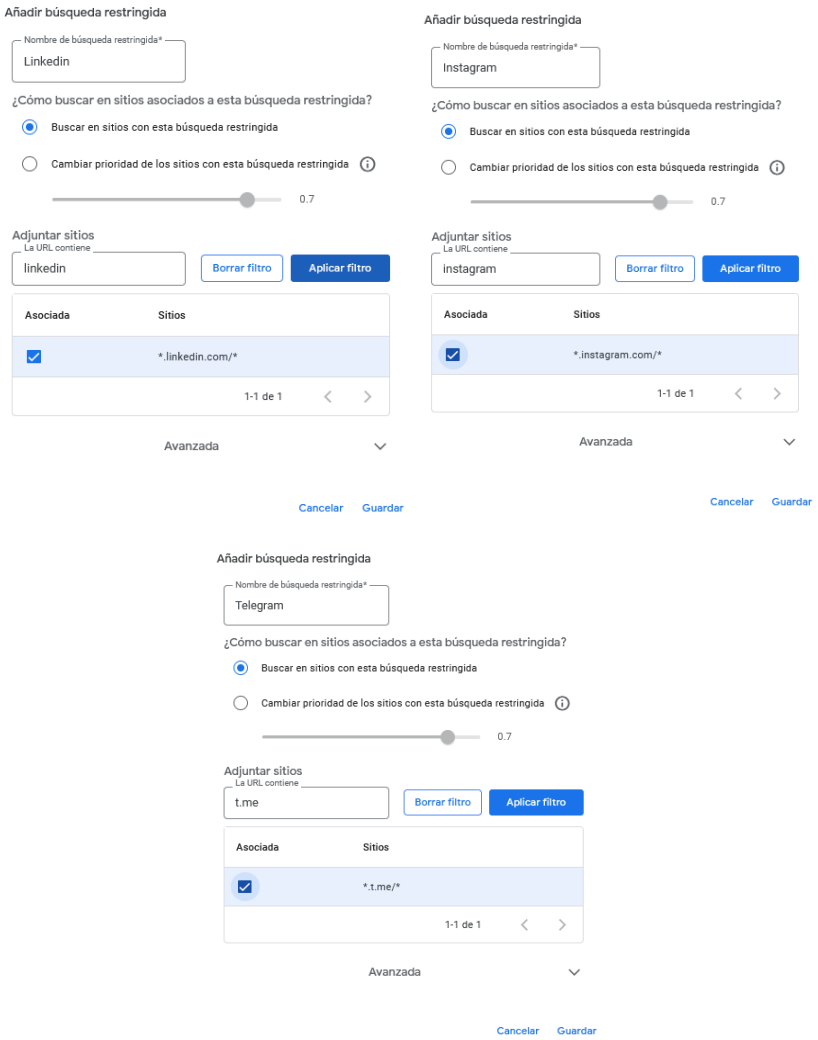


Imagen 86. Configuración de la búsqueda restringida de LinkedIn, Instagram y Telegram

En este momento ya tendríamos todas las búsquedas restringidas totalmente personalizadas, tal como puede verse en la Imagen 87.

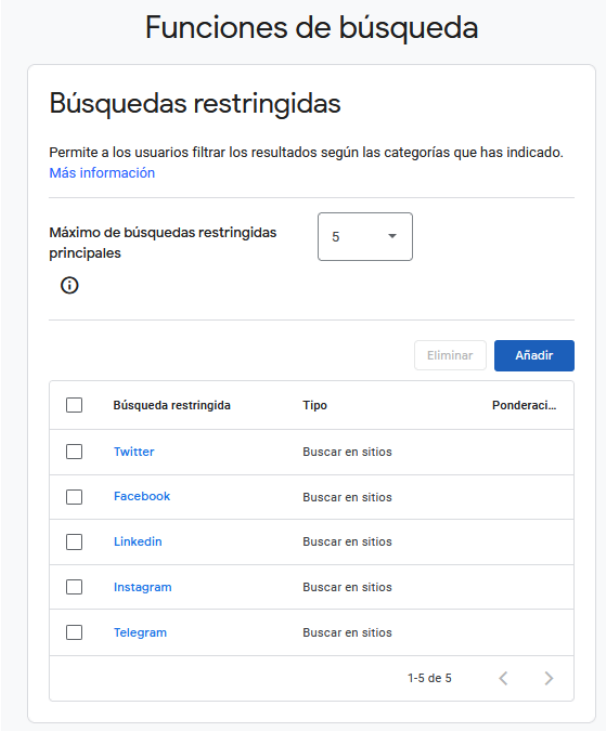


Imagen 87. Parametrización finalizada de las búsquedas restringidas

Si accedemos a la URL pública del buscador recién creado nos damos cuenta de que ha aparecido una pestaña por cada fuente añadida al buscador, pudiendo filtrar por dichas pestañas tanto por web como por imágenes. En la Imagen 88 podemos ver el filtrado por el tipo de fuente de Twitter y Telegram.

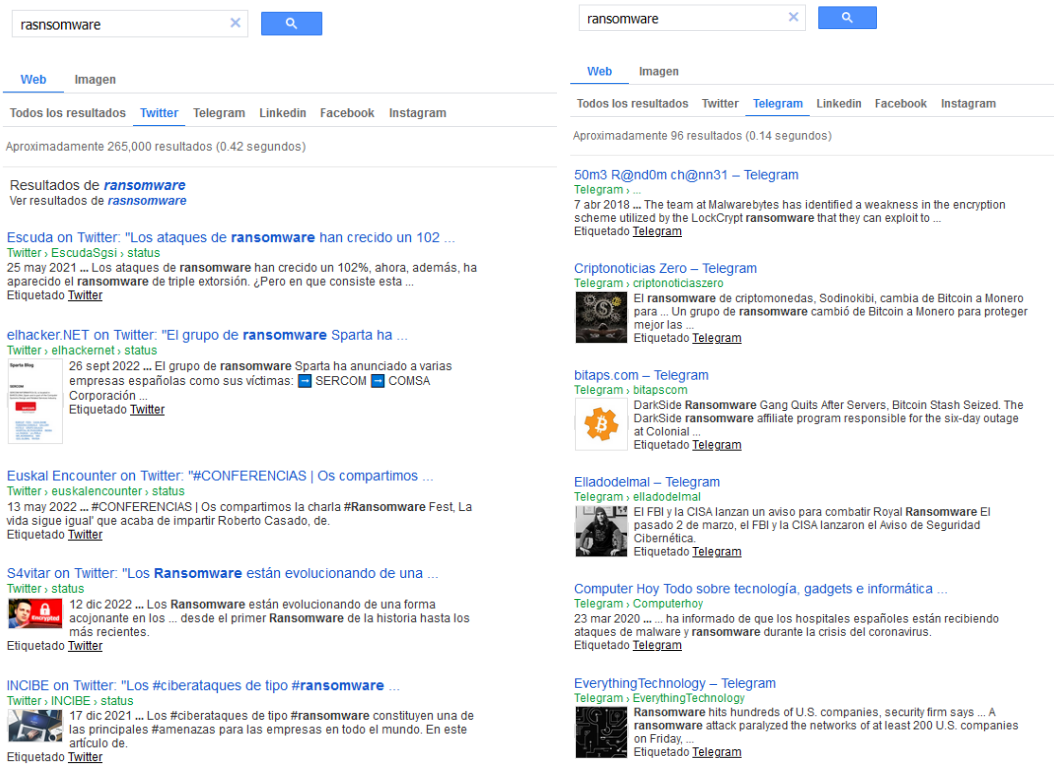


Imagen 88. Resultados de Twitter y Telegram mediante el buscador CSE

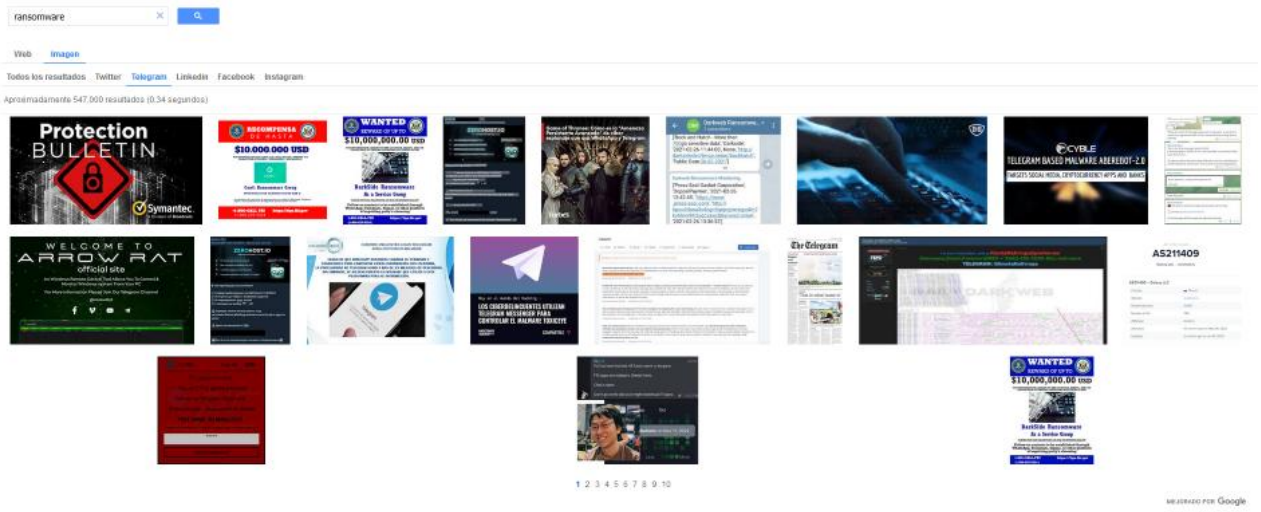


Imagen 89. Resultados de imágenes de Telegram en el buscador CSE

3.1.2. BING HACKING

Bing es el buscador de Microsoft y como se puede apreciar en la Tabla 2, los operadores son muy similares a los que hemos visto anteriormente con las Google Dorks. Los resultados obtenidos en cada buscador están relacionados con los propios rastreadores web que utilicen, pudiendo recolectar diferentes resultados con distintos tipos de buscadores utilizando la misma dork. El enlace de acceso a Bing es el siguiente: https://www.bing.com

Dork	Descripción
"Búsqueda exacta"	Buscar frase exacta utilizando las comillas (" ")
-	Eliminar de los resultados de búsqueda sobre las páginas que mencionan un término determinado
+	Obligar a Bing a devolver palabras comunes que normalmente se descartarían
OR	Buscar un término de búsqueda dado u otro término
site:	Buscar por un dominio dado
filetype:	Buscar por un determinado tipo de fichero
ext:	Buscar por un determinado tipo de extensión de fichero
intitle:	Buscar sitios con la palabra clave objetivo en el título de la página web
inurl:	Buscar sitios con la palabra clave objetivo en la URL
ip:	Buscar una dirección IP como objetivo
domain:	Buscar un dominio específico como objetivo
intext:	Buscar sitios con la palabra clave objetivo en el contenido de una página web

inarchor:	Buscar sitios con la palabra calve objetivo en enlaces que apunten a ellos
cache:	Mostrar la cache más reciente de una página web
instreamset:(url):	Buscar sitios que contienen términos específicos en la URL

Tabla 2. Listado de operadores básicos de Bing

Ahora que ya se conocen los operadores básicos con Bing, vamos a ir construyendo diferentes dorks más complejas, reaprovechando en algunos ejemplos las mismas consultas utilizadas con Google Dorks.

- Buscar la palabra clave "intranet" dentro de las URL de una página web, donde en dichos resultados filtre por el tipo de fichero ".doc" y sobre los resultados realice una búsqueda de la palabra clave "confidential" dentro del contenido del sitio web.

inurl:intranet **filetype**:doc **intext**:confidential

En la Imagen 90 puede comprobarse el resultado de la dork, devolviendo *un único resultado*, permitiendo la descarga de un documento .doc.



Imagen 90. Buscando documentos confidenciales

- Buscar la frase clave "Live view / – AXIS" dentro del título de una página web con el objetivo de detectar sitios web relacionados con cámaras web de la marca AXIS y excluyendo los resultados que procedan de Twitter.

```
intitle:"Live view / – AXIS" -site:twitter.com
```

En la Imagen 91 puede comprobarse el resultado de la dork, devolviendo un total de *1.080 resultados* relacionados con cámaras web AXIS, permitiendo el acceso a sitios web donde se puede visualizar su contenido.

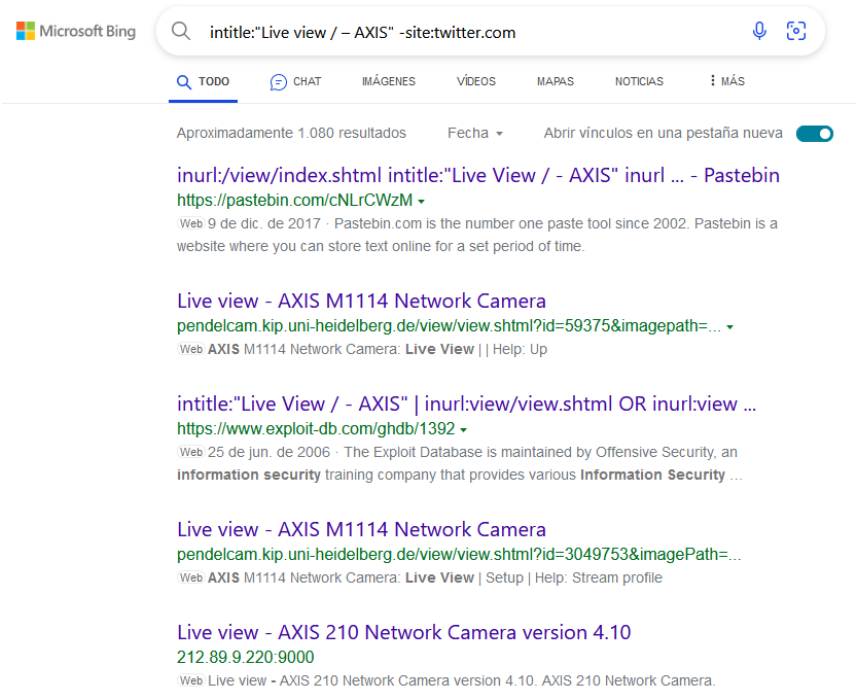


Imagen 91. Búsqueda de cámaras web de la marca AXIS

Como se ha podido comprobar en las imágenes 90 y 91 las mismas dorks utilizadas con Google funcionan correctamente en Bing.

3.1.3. BAIDU

Cuarto proveedor de búsqueda en cuota de mercado a nivel mundial, también conocido como el "Google Chino".

En China es el principal motor de búsqueda; sin embargo, está limitado por la férrea censura estatal china que supervisa de cerca y bloquea gran parte de los sitios internacionales, promoviendo así ciertos plataformas y webs locales en su lugar.

Tal como ocurre con Google y Bing, en su gran mayoría Baidu permite utilizar los mismos operadores. El enlace de acceso a Baidu es el siguiente: http://www.baidu.com.

Dork	Descripción
"Búsqueda exacta"	Buscar frase exacta utilizando las comillas (" ")
-	Eliminar de los resultados de búsqueda sobre las páginas que mencionan un término determinado
+	Obligar a Baidu a devolver palabras comunes que normalmente se descartarían
OR	Buscar un término de búsqueda dado u otro término
site:	Buscar por un dominio dado
filetype:	Buscar por un determinado tipo de fichero
ext:	Buscar por un determinado tipo de extensión de fichero
intitle:	Buscar sitios con la palabra clave objetivo en el título de la página web
inurl:	Buscar sitios con la palabra clave objetivo en la URL

intext:	Buscar sitios con la palabra clave objetivo en el contenido de una página web
cache:	Mostrar la cache más reciente de una página web

Tabla 3. Listado de operadores básicos de Baidu

Ahora que ya se conocen los operadores básicos con Baidu, vamos a reaprovechar el ejemplo de la búsqueda realizada en Google y Bing sobre la cámara web AXIS.

Buscar la frase clave "Live view / – AXIS" dentro del título de una página web con el objetivo de detectar sitios web relacionados con cámaras web de la marca AXIS y excluyendo los resultados que procedan de Twitter.

```
intitle:"Live view / – AXIS" -site:twitter.com
```

En la Imagen 92 puede comprobarse el resultado de la dork, pero visualizamos todo el contenido en chino y es difícil realizar una investigación mediante dicho idioma. Por este motivo es recomendable utilizar un plugin de navegador para realizar las traducciones al vuelo a medida que estamos investigando. Una recomendación para ello es **TWP - Translate Web Pages** que utiliza los motores de Google y Yandex y puede ser encontrado como plugin de Firefox en el siguiente enlace: https://addons.mozilla.org/es/firefox/addon/traduzir-paginas-web/. En la Imagen 93 puede verse como traduce todo correctamente a castellano, lo único que no se detecta el número total de resultados por ninguna parte de la web.

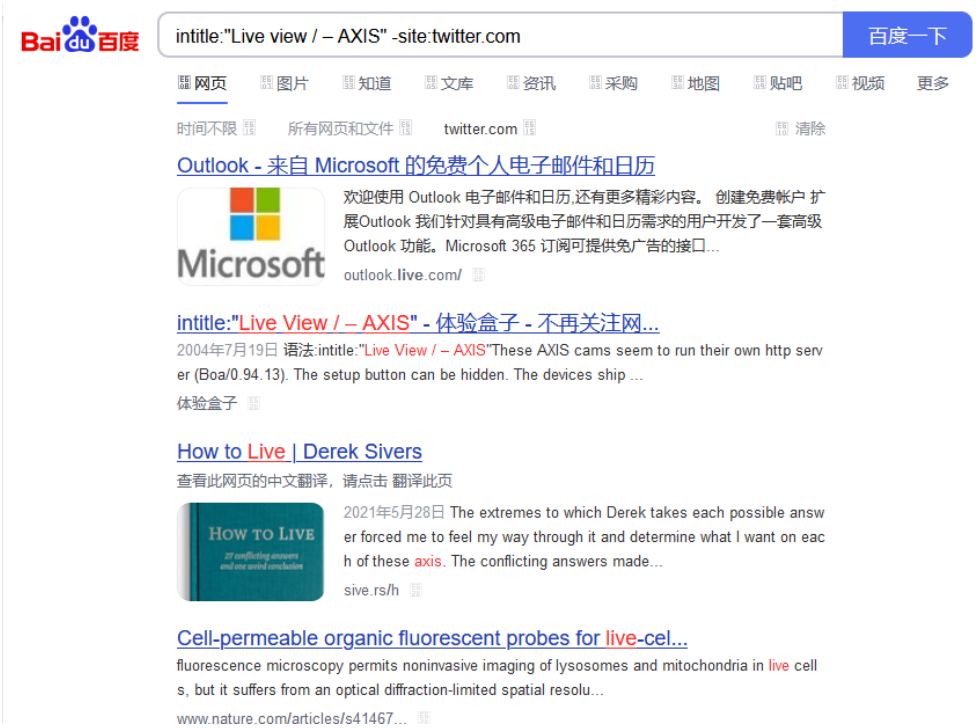


Imagen 92. Búsqueda de cámaras web de la marca AXIS

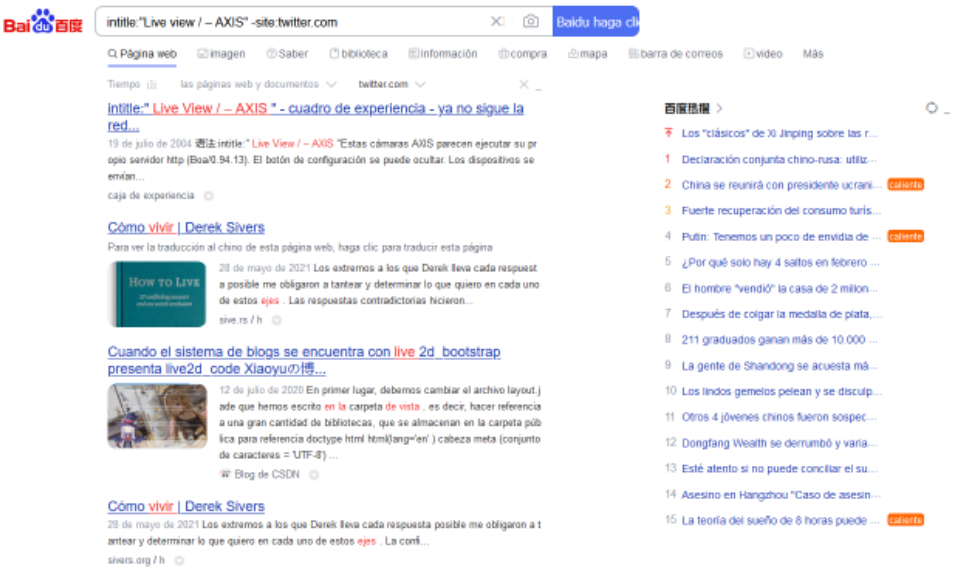


Imagen 93. Traducción de la Imagen 92 con el plugin TWP

3.1.4. YANDEX

Quinto proveedor de búsqueda más grande del mundo, que controla más del 61% de las búsquedas en Rusia y en otros países de su área idiomática, como Kazajstán, Bielorrusia y Ucrania.

Tal como ocurre con los otros buscadores genéricos, en su gran mayoría Yandex permite utilizar los mismos operadores. El enlace de acceso a Yandex es el siguiente: https://yandex.com/.

Dork	Descripción
"Búsqueda exacta"	Buscar frase exacta utilizando las comillas (" ")
-	Eliminar de los resultados de búsqueda las páginas que mencionan un término determinado
+	Obligar a Yandex a devolver palabras comunes que normalmente se descartarían
|	Buscar un término de búsqueda dado u otro término
site:	Buscar por un dominio dado
filetype:	Buscar por un determinado tipo de fichero
ext:	Buscar por un determinado tipo de extensión de fichero
intitle:	Buscar sitios con la palabra clave objetivo en el título de la página web
inurl:	Buscar sitios con la palabra clave objetivo en la URL
intext:	Buscar sitios con la palabra clave objetivo en el contenido de una página web
cache:	Mostrar la cache más reciente de una página web
mime:	Permite hacer búsquedas por tipo de fichero
date:	Permite buscar coincidencias mediante fechas dadas
url:	Permite listar toda la información de una URL concreta
host:	Permite listar toda la información de un host concreto

domain:	Permite listar toda la información de un dominio concreta

Tabla 4. Listado de operadores básicos de Yandex

Ahora que ya se conocen los operadores básicos con Yandex, vamos a buscar por tipo de fichero .doc junto con la palabra clave "confidential".

mime:doc +confidential

En la Imagen 91 puede comprobarse el resultado de la dork, devolviendo un total de *333 resultados* relacionados con archivos con formato .doc.

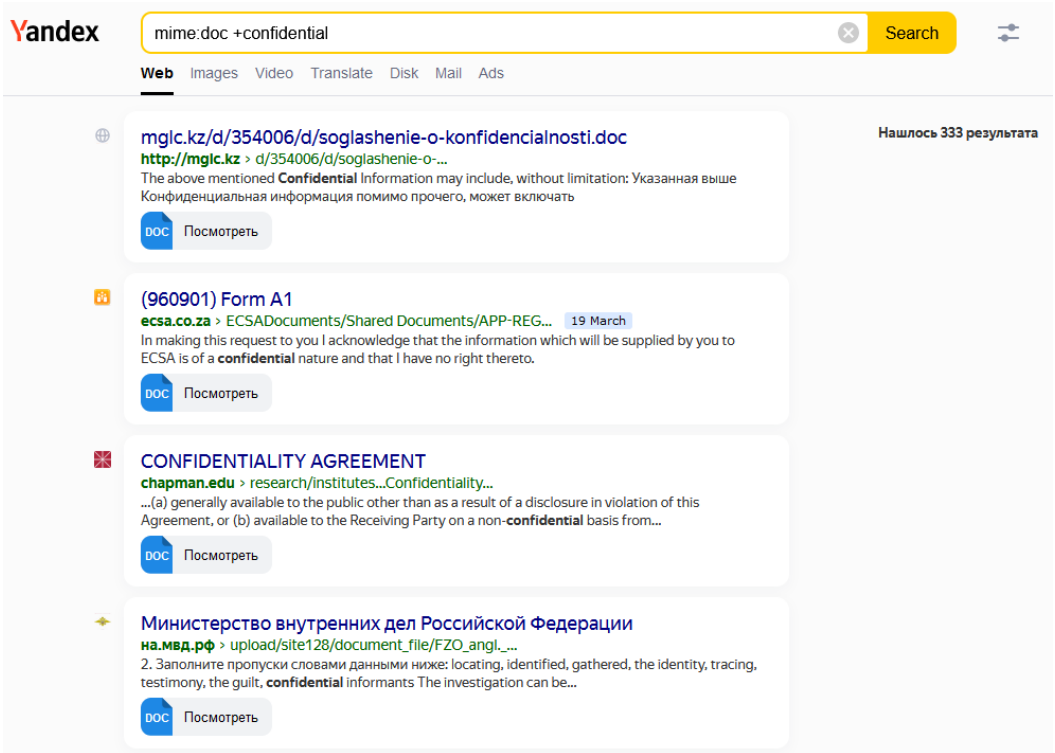


Imagen 94. Resultados de la dork realizada en Yandex

3.1.5. CARROT2

Carrot2 es un tipo de buscador algo diferente al resto de buscadores genéricos en cuanto a la representación de los resultados se refiere. Dichos resultados pueden visualizarse mediante una categorización de carpetas, un TreeMap o gráfico de anillo. El enlace de acceso es el siguiente: https://search.carrot2.org.

En la Imagen 95 (visualización por carpetas) e Imagen 96 (visualización por TreeMap) puede verse el resultado de la palabra clave "ransomware" en Carrot2

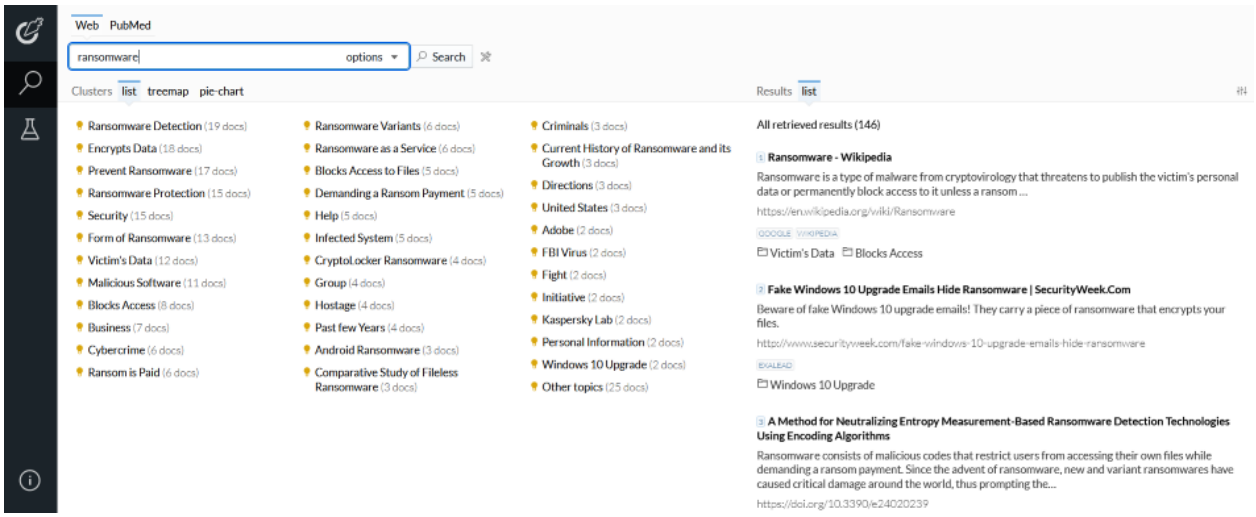


Imagen 95. Búsqueda de la palabra clave "ransomware" en Carrot2 con visualización por carpetas



Imagen 96. Búsqueda de la palabra clave "ransomware" en Carrot2 con visualización por TreeMap

3.2. BUSCADORES ESPECIALIZADOS

Los buscadores especializados permiten obtener gran información relevante sobre una cuestión o tema específico. A pesar de que existe gran cantidad de subtipos, resulta fundamental destacar entre estos los orientados al Internet de las Cosas (IoT), que identifican e indexan en su índice otro tipo de información más centrada en la tecnología, tal como direcciones IP, puertos y servicios de dispositivos expuestos a Internet. Los buscadores que podemos encontrar en esta sección son los siguientes:







3.2.1. SHODAN

Shodan es un tipo de buscador que realiza a bajo nivel un ZMAP hacia todos los dispositivos o servidores conectados a Internet ofreciendo datos relacionados a través de un buscador o mediante consulta a su API. Es un tipo de buscador que está en desarrollo y evolución constante, como puede ser el módulo de Exploits para realizar búsquedas sobre vulnerabilidades o el módulo de Honeypot or Not. Se trata de un buscador de pago. El enlace de acceso está disponible aquí: https://www.shodan.io.

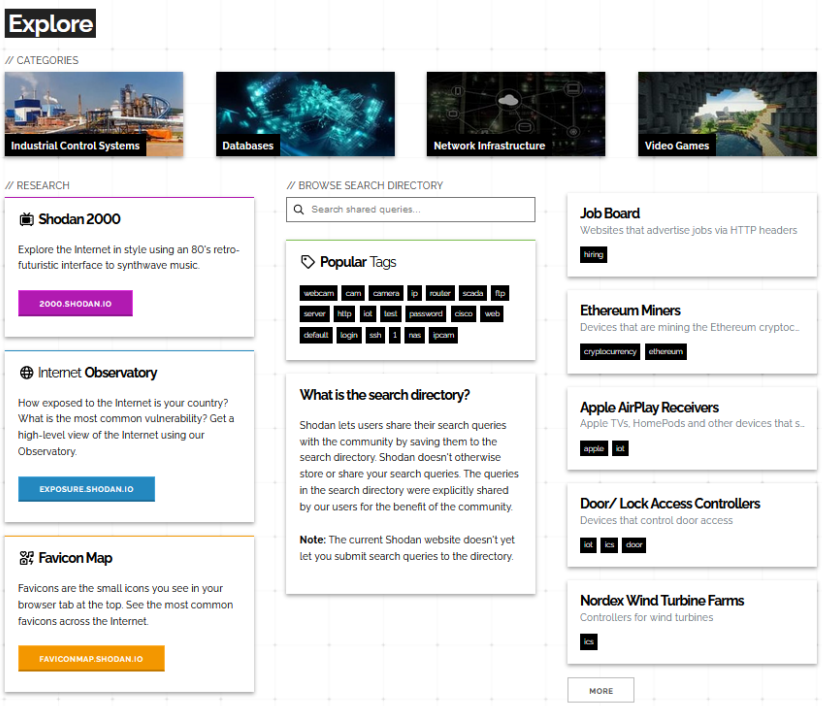


Imagen 97. Dashboard Explore de Shodan

En la Imagen 97 puede verse la pantalla del módulo "explore" de Shodan, donde nos ofrece la posibilidad de investigar por Sistemas de Control Industrial, base de datos, infraestructura de red, videojuegos, mapas, etc.

Shodan tiene una serie de operadores que permiten realizar búsquedas mucho más avanzadas si se combinan entre sí.

Dork	Descripción
country:	Permite filtrar por sistemas publicados en un país concreto
city:	Permite filtrar por la ciudad en la que se encuentre un sistema.
geo:	Permite filtrar por las coordenadas de latitud y longitud.
port:	Permite filtrar por puertos específicos.
net:	Permite filtrar por una IP específica o por rangos de IP.
hostname:	Permite para filtrar por nombre de host.
os:	Permite filtrar por sistema operativo.
before/after:	Permite filtrar por fechas anterior a o después de.
has_screenshot:	Permite comprobar si un objetivo tiene activado un pantallazo

Tabla 5. Listado de operadores básicos de Shodan

Vamos a realizar una serie de investigaciones por objetivo utilizando el buscador Shodan, siendo las siguientes:

- Buscar direcciones IP que tengan en ejecución un producto Apache y estén ubicados en España.

```
product:Apache country:"ES"
```

En la Imagen 98 puede comprobarse el resultado de la dork, devolviendo un total de *170.383 resultados* con la siguiente información: **Top5 de ciudades** (Madrid,

Barcelona, Valencia, Sevilla y Bilbao), **Top5 de puertos abiertos** (81, 443, 8080, 8081 y 8443) y **Top5 de versiones de Apache** (2.4.6, 2.4.38, 2.4.29, 2.4.41 y 2.4.54).

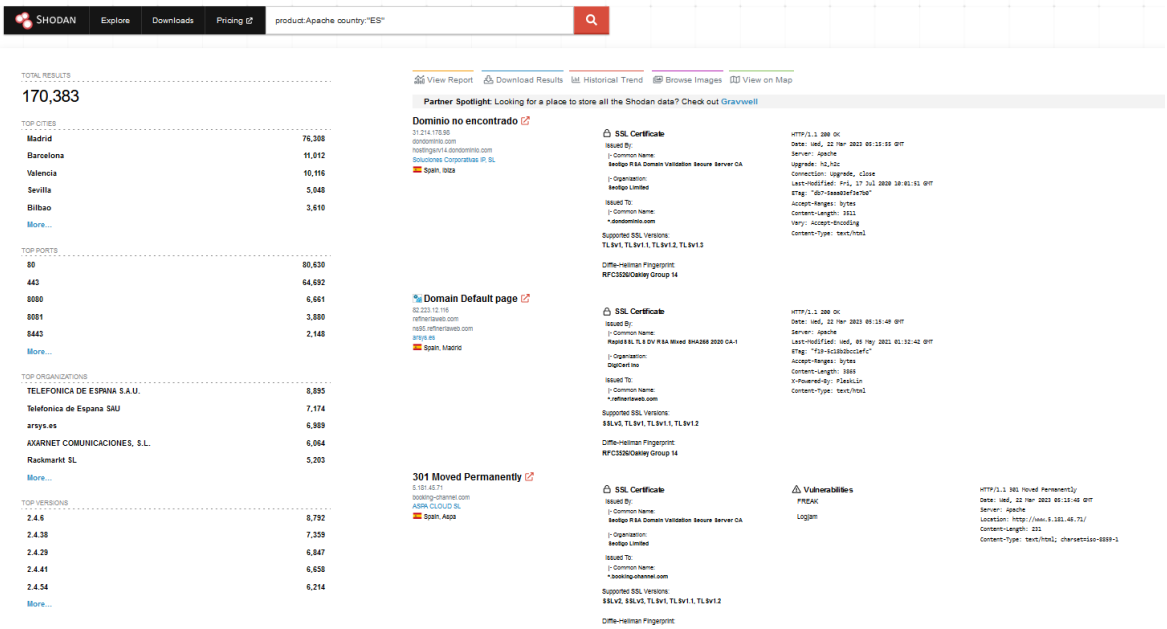


Imagen 98. Resultados de producto Apache localizados en España

- Buscar direcciones IP y servicios expuestos realizando una búsqueda por el dominio, en este caso google.com, asociado a los certificados.

ssl.cert.subject.cn:google.com

En la Imagen 99 puede comprobarse el resultado de la dork, devolviendo un total de *15.568 resultados* con la siguiente información: **Top5 de países** (Estados Unidos, Alemania, Hong Kong, India y Singapur), **Top5 de puertos abiertos** (443, 25, 21, 8443 y 993), **Top5 de productos** (nginx, Apache, Exim, Microsoft HTTAPI y Postfix) y **Top5 de organizaciones** (Google LLC, EU metro, Asia Pacific Network Information Centre, Hetzner Online GmbH y Google Argentina SRL).

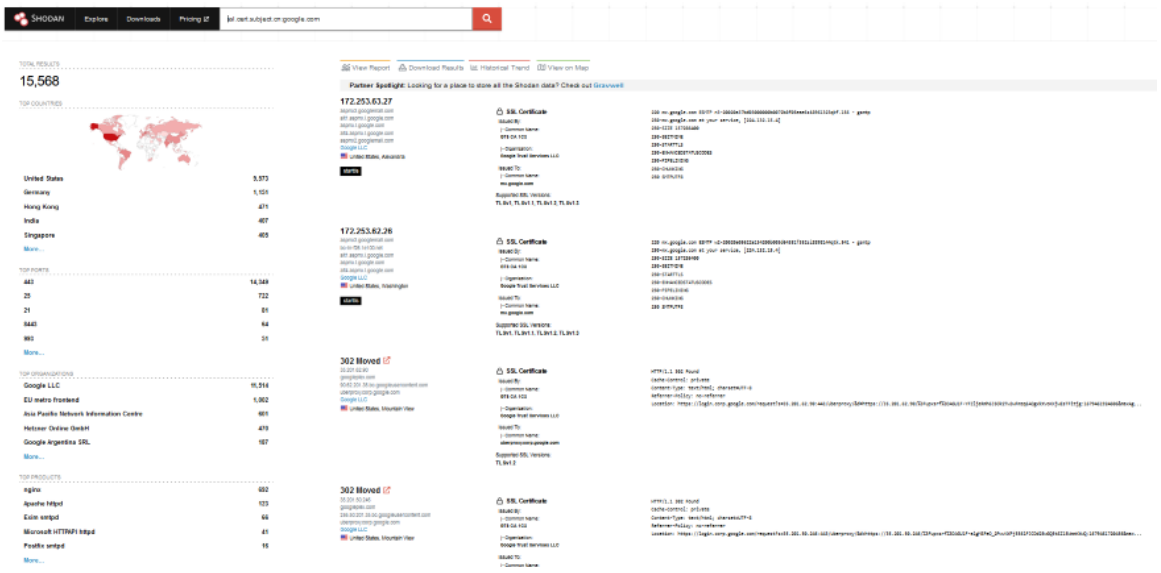


Imagen 99. Resultados de búsqueda de dominio por SSL

- Buscar direcciones IP que tengan expuesto un servicio de Escritorio Remoto y permita buscar información mediante OCR para detectar si el activo ha sido comprometido por un ransomware.

```
has_screenshot:true encrypted attention
```

En la Imagen 100 puede comprobarse el resultado de la dork, devolviendo un total de 4 *resultados* con la siguiente información: **Top3 de países** (Estados Unidos, Suecia y Vietnam), **Top3 de sistemas operativos** (Windows Server 2012 R2, Windows (Build 10.0.14393 y Windows Server 2008 R2)) y **Top4 de organizaciones** (Amazon, Internetport Sweden, OVH y Vietnam Post and Telecommunications Group).

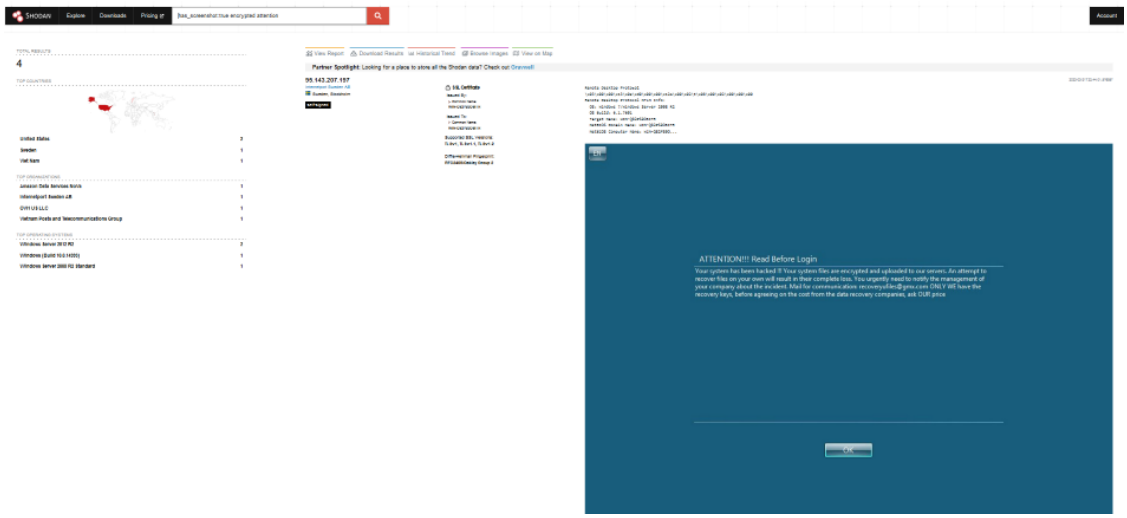


Imagen 100. Resultados de búsqueda de direcciones IP comprometidas por ransomware

Se disponen de más ejemplos de búsquedas con Shodan en el siguiente enlace: https://www.shodan.io/search/examples.

Por medio de la API es posible recopilar información de cada objeto de la dirección IP que esté presente en Shodan asociado al nombre de una organización (con parámetro "org") o con el Rango IP perteneciente a la organización (con parámetro "net"). En la tabla inferior pueden verse como se ejecutan dichos parámetros con Python.

```
search = api.search('org:"'+str(org)+'"')
search = api.search(net:"'+str(net)+'"')
```

Por medio de los resultados obtenidos de las queries anteriores podemos buscar por cada dirección IP recopilada, toda la información relacionada a esta. Con lo mencionado estamos comprobando que información está expuesta a Internet y si alguno de sus elementos tiene una vulnerabilidad asociada a explotar (ver Imagen 101).

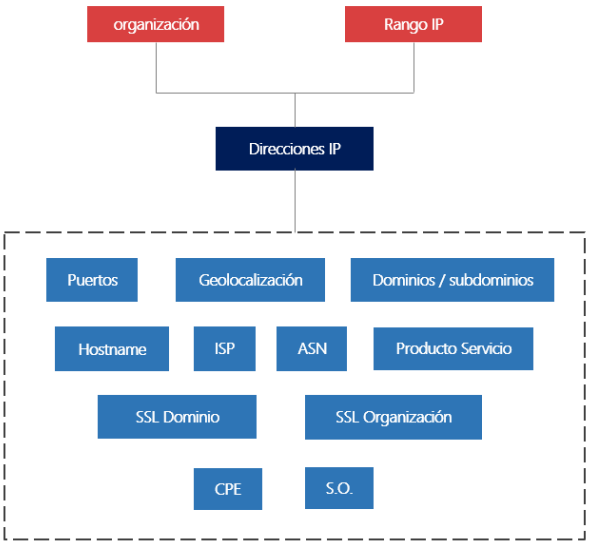


Imagen 101. Información obtenida con Shodan

Shodan dispone de un módulo de exploits en los que poder realizar búsquedas tanto desde la web como por API. Una vez que se ha obtenido información sobre los puertos y el nombre del producto del servicio es posible detectar que tipo de servicio tiene en ejecución un activo concreto. En ese momento podemos relacionar esto último y realizar búsquedas en el módulo de Exploits de Shodan, tal como se ha realizado en la Imagen 102 con el puerto 9200 correspondiente a la Base de Datos Elasticsearch. El acceso a dicho módulo puede encontrarse en el siguiente enlace: https://exploits.shodan.io/welcome.

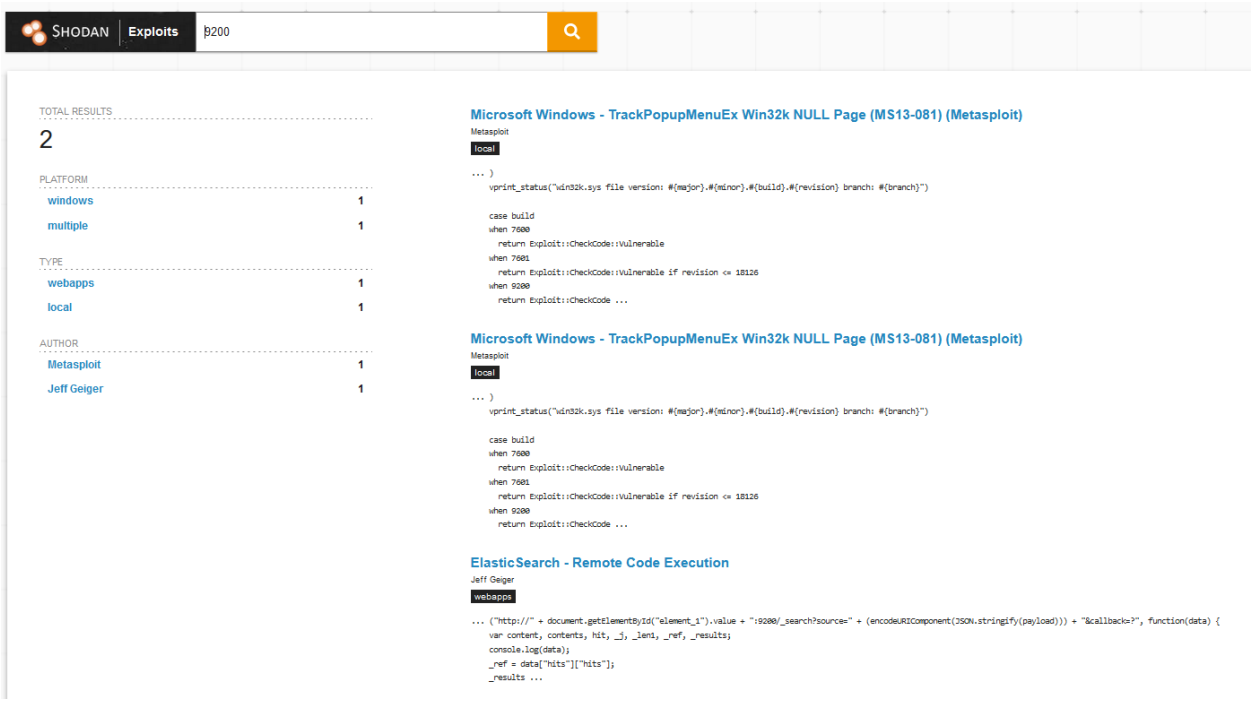


Imagen 102. Búsqueda en el módulo de Exploits de Shodan

3.2.2. CENSYS

Censys es un buscador similar a Shodan que va a permitir detectar los activos conectados a Internet y que están relacionados con direcciones IPv4, IPv6, dominios y certificados. Esta herramienta debe ser utilizada de manera complementaria a Shodan para poder descubrir activos o servicios expuestos a Internet que no hayan sido detectados por Shodan. Se trata de un buscador de pago, pero permite realizar búsquedas con el módulo Hosts.

Los accesos a cada uno de los módulos mencionados anteriormente son los siguientes:

- Hosts (ver Imagen 103): https://censys.io/ipv4

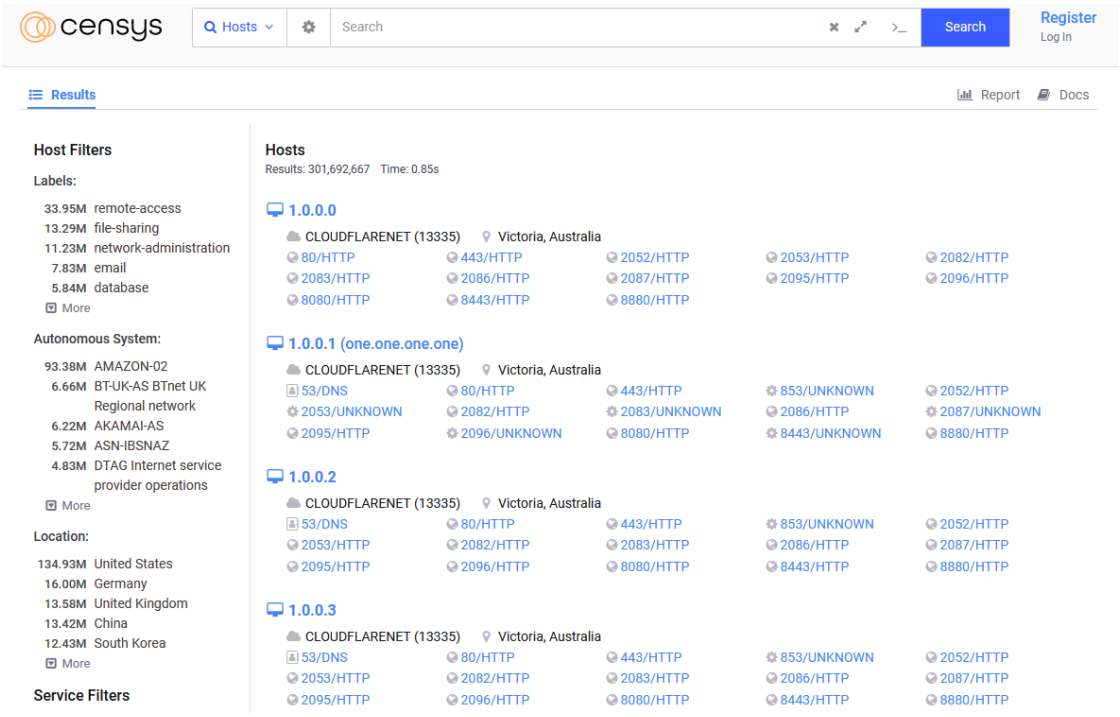


Imagen 103. Módulo de hosts de Censys

- Certificados: https://search.censys.io/certificates?resource=certificates

Censys tiene una serie de operadores que permiten realizar búsquedas mucho más avanzadas si se combinan entre sí.

Dork	Descripción
and	Anidar diferentes operadores entre sí
or	Buscar un término de búsqueda dado u otro término
not	Eliminar de los resultados de búsqueda las direcciones IP y servicios que mencionan un término determinado
[]	Permite filtrar por rangos numéricos inclusivos
{}	Permite filtrar por rangos numéricos exclusivos
?	Permite reemplazar un solo carácter
*****	Permite reemplazar cero o más caracteres

^	Permite dar mayor relevancia a un término en la búsqueda
ip:	Permite buscar por rango IP concreto con el siguiente formato: **xxx.xxx.xxx.xxx/xx**
ip:[]	Permite buscar entre una serie de direcciones IP específicas con el siguiente formato: **ip: [xxx.xxx.xxx.xxx TO xxx.xxx.xxx.xxx]**
[xxxx-xx-xx TO xxxx-xx-xx]	Permite buscar entre rangos de fechas o mediante rango de fecha abierto por ejemplo: **[xxxx-xx-xx TO *]**
a:	Permite buscar dirección IP asociada a un dominio
mx:	Permite buscar si un dominio dispone de servidor de correo

Tabla 6. Listado de operadores básicos de Censys

Toda la información respecto a su API la podéis encontrar en el siguiente enlace: https://censys.io/api

CENSYS dispone de unos módulos desarrollados en Python donde consultar datos mediante la API sobre IPv4, dominios y certificados en el siguiente enlace: https://github.com/censys/censys-python.

3.2.3. ZOOMEYE

ZOOMEYE es una herramienta similar a las anteriores pero esta vez desarrollados por los chinos. Por detrás dispone de dos motores de detección que son XMAP y WMAP, que no son más que escáneres utilizados para detectar activos conectados a Internet y vulnerabilidades asociadas. En el icono situado en la parte superior derecha del sitio web principal, podéis cambiar el idioma a inglés. A continuación se facilitan los enlaces a la herramienta online:

- Buscador de ZoomEye (ver Imagen 104): https://www.zoomeye.org.
- Estadísticas con ZoomEye (Ver Imagen 105): https://www.zoomeye.org/statistics
- Documentación de la API: https://www.zoomeye.org/doc.

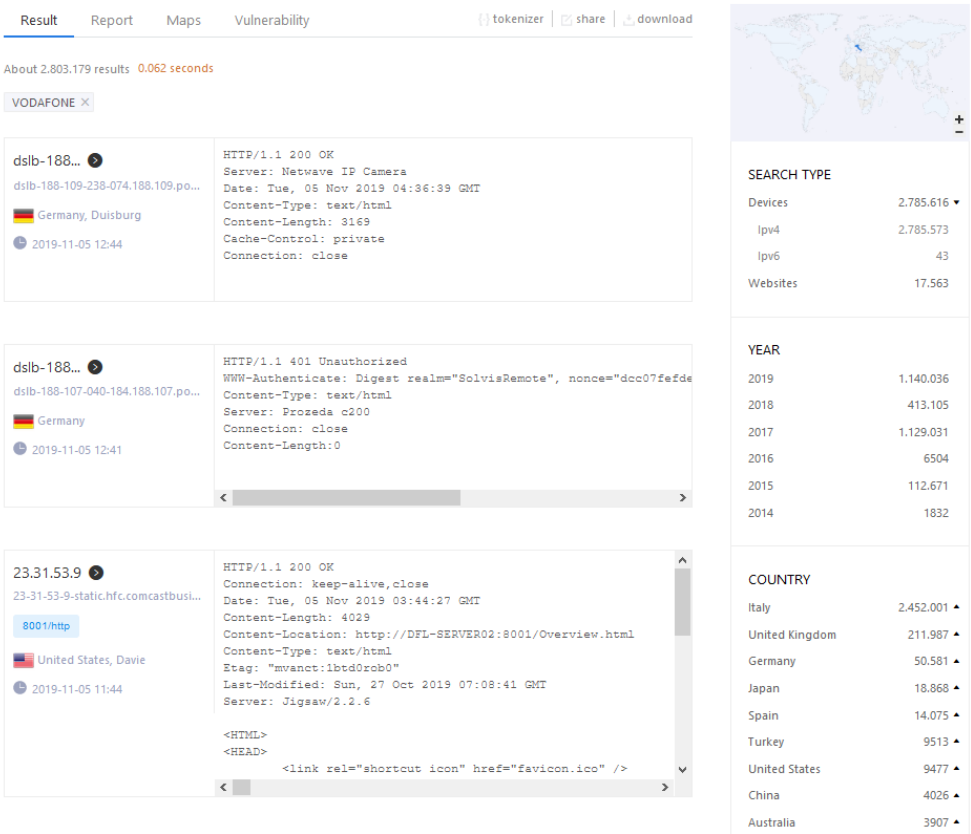


Imagen 104. Buscador de ZoomEye



Imagen 105. Estadísticas de ZoomEye

ZoomEye tiene una serie de operadores que permiten realizar búsquedas mucho más avanzadas si se combinan entre sí.

Dork	Descripción
site:	Permite buscar por nombre de dominio
ip:	Permite hacer búsquedas para una dirección IP específica
cidr:	Permite hacer búsquedas para un rango IP
port:	Permite buscar activos indexados por puerto concreto
country:	Permite hacer búsquedas por país; resulta necesario introducir el código de país
title:	Permite buscar resultados que contengan términos específicos en el título de una web
os:	Permite realizar búsquedas que contengan sistemas operativos específicos
after:	Permite buscar activos actualizados antes de una fecha concreta

before:	Permite buscar activos actualizados después de una fecha concreta

Tabla 7. Listado de operadores básicos de ZoomEye

3.3. BUSCADORES DE IMÁGENES

Los servicios de búsqueda inversa de imágenes permiten verificar la exposición de estas, identificando así otros dominios en los que puedan aparecer. De esta forma, tenemos ante nosotros una herramienta muy potente que nos puede ayudar a detectar diferentes aspectos relacionados con las imágenes, siendo las siguientes:

- Detectar la misma imagen compartida en diferentes medios digitales
- Reutilización de una imagen de perfil en diferentes perfiles de redes sociales y/o foros
- Análisis de metadatos asociados a la imagen
- Análisis de objetos que aparecen en la imagen
- Obtención de las coordenadas desde donde se hizo la foto
- Extracción de texto de la imagen

Existen diferentes herramientas entre las que destacan: Google Imágenes, Yandex, Bing Imágenes y TinEye.

3.3.1. GOOGLE

Google dispone de un servicio de búsqueda inversa de imágenes, permitiendo subir como punto de entrada una imagen a nivel local o bien por medio de una URL. El enlace de acceso a dicho servicio es el siguiente: https://images.google.com/.

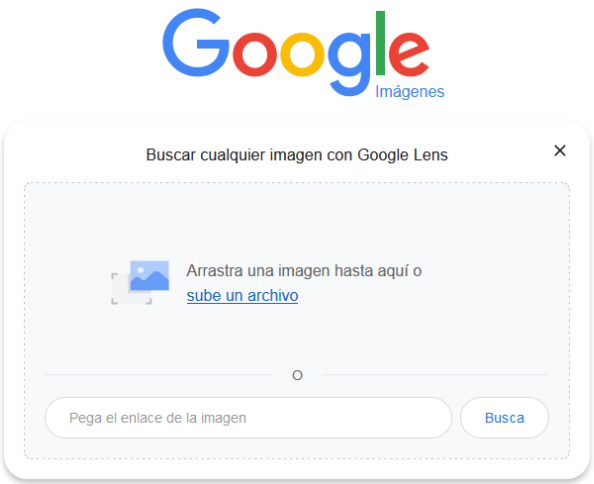


Imagen 106. Página principal de Google Images

Para este ejemplo vamos a utilizar la imagen que aparece en el tweet de la Imagen 107, donde lo primero que se tendrá que hacer es obtener la URL de la propia imagen. El enlace del tweet es el siguiente: https://twitter.com/gerasimoffs937/status/914544473471950848.



Imagen 107. Imagen del tweet a analizar mediante búsqueda inversa de imágenes

Una vez descargada o copiada la URL de la imagen, se procede a pegar dicha URL en el cuadro de texto de la Imagen 106 para realizar la búsqueda. Tal como vemos en la Imagen

108, podemos observar las coincidencias a nivel de similitud de la imagen con otras imágenes que el propio motor de Google nos muestra.

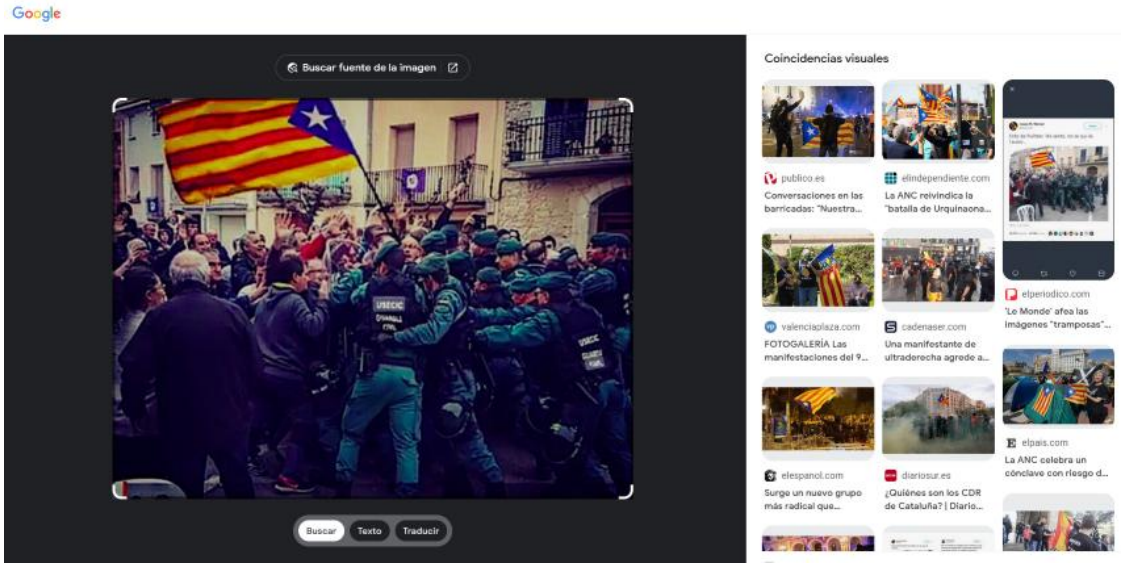


Imagen 108. Resultado ofrecido por Google Images

Desde hace unos años, Google añadió la opción gracias al servicio LENS, de poder extraer información y analizar objetos dentro de las imágenes. En la Imagen 109 se puede apreciar que detecta el texto escrito en el chaleco del Guardia Civil, siendo dicha palabra "USECIC".



Imagen 109. Búsqueda de texto con Google Images

Ahora, si le indicamos a Google que deseamos buscar por fuente de la imagen, cambiará el diseño de su sitio web, tal como se puede apreciar en la Imagen 110. Los resultados se dividen en tres secciones: resultados sobre lo que cree el algoritmo de Google que hay en la foto, resultados visualmente similares (pero no idénticos) y sitios web detectadas que tienen imágenes idénticas. Ahora tocaría investigar a fondo cada evidencia para identificar el origen real de la imagen.

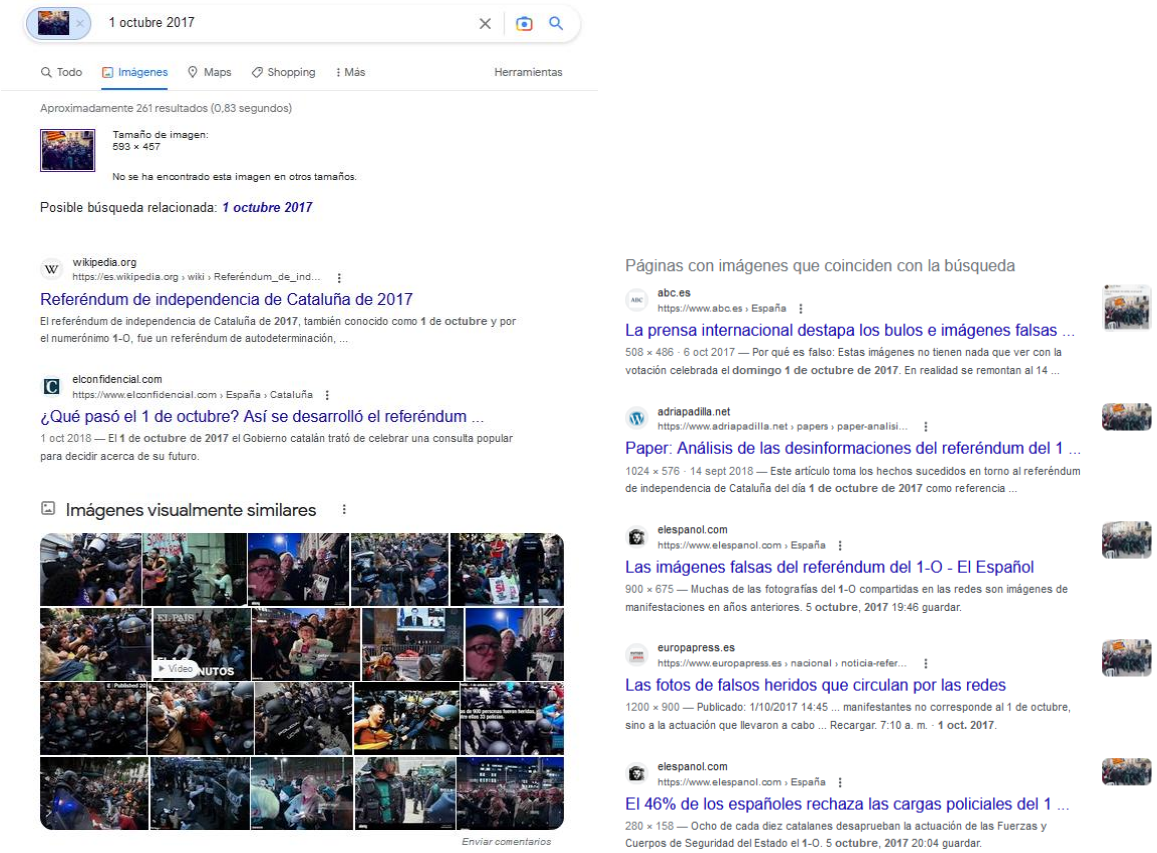


Imagen 110. Resultados de Google Images por fuente de origen

3.3.2. BING

Bing dispone de un servicio de búsqueda inversa de imágenes, permitiendo subir como punto de entrada una imagen a nivel local o bien por medio de una URL.

Bing es capaz de identificar diferentes objetos dentro de una imagen y detectar imágenes que contengan todos esos elementos, además, de detectar rostros, productos y otros elementos de la propia imagen y mostrar resultados similares.

El enlace de acceso a dicho servicio es el siguiente: https://www.bing.com/images/search.

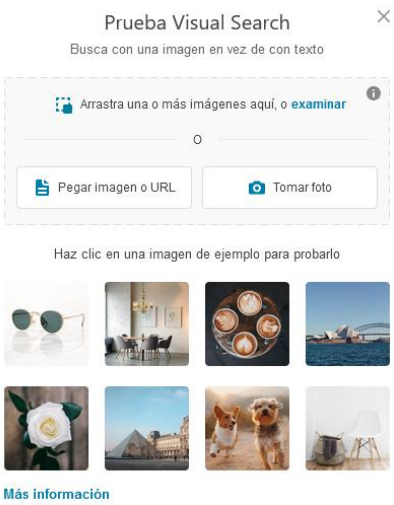


Imagen 111. Página principal de Bing Images

Procedemos a utilizar el mismo ejemplo de Google Images pero utilizando Bing Images. Tal como vemos en la Imagen 112, podemos observar las coincidencias a nivel de similitud de la imagen con otras imágenes que el propio motor de Bing nos muestra. Bing permite recortar áreas de la imagen y ver los resultados en directo, aunque a diferencia que Google, Bing únicamente nos mostrará resultados en forma de imágenes.

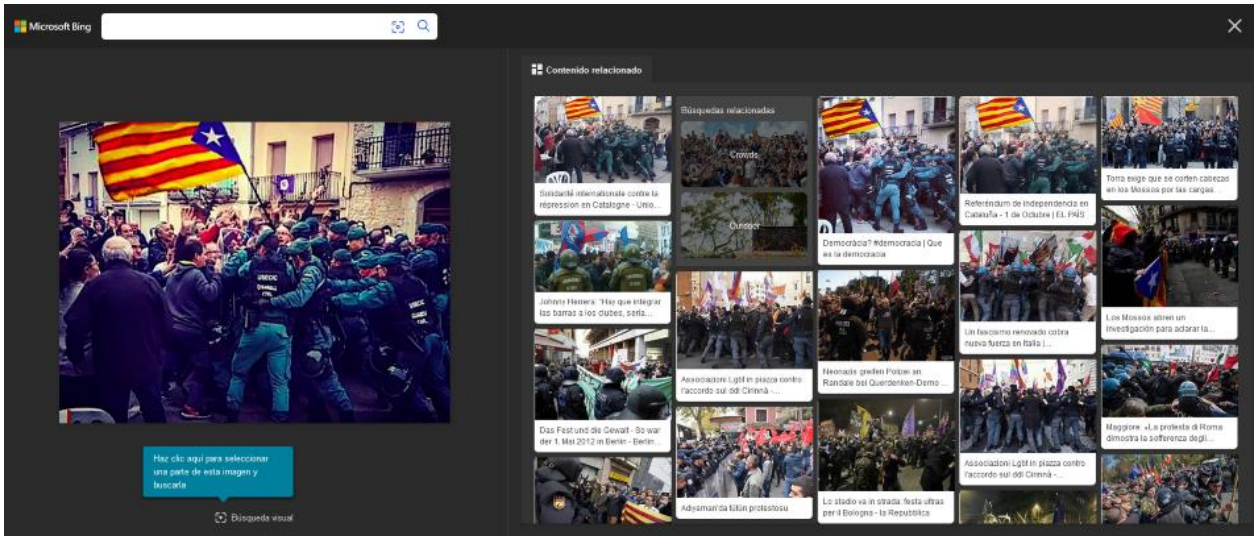


Imagen 112. Resultados obtenidos con Bing Images

3.3.3. YANDEX

Yandex dispone de un servicio de búsqueda inversa de imágenes, permitiendo subir como punto de entrada una imagen a nivel local o bien por medio de una URL. Yandex dispone de un motor de búsqueda idóneo para realizar búsqueda de rostros e identificación de ubicaciones. El enlace de acceso a dicho servicio es el siguiente: https://yandex.com/images.

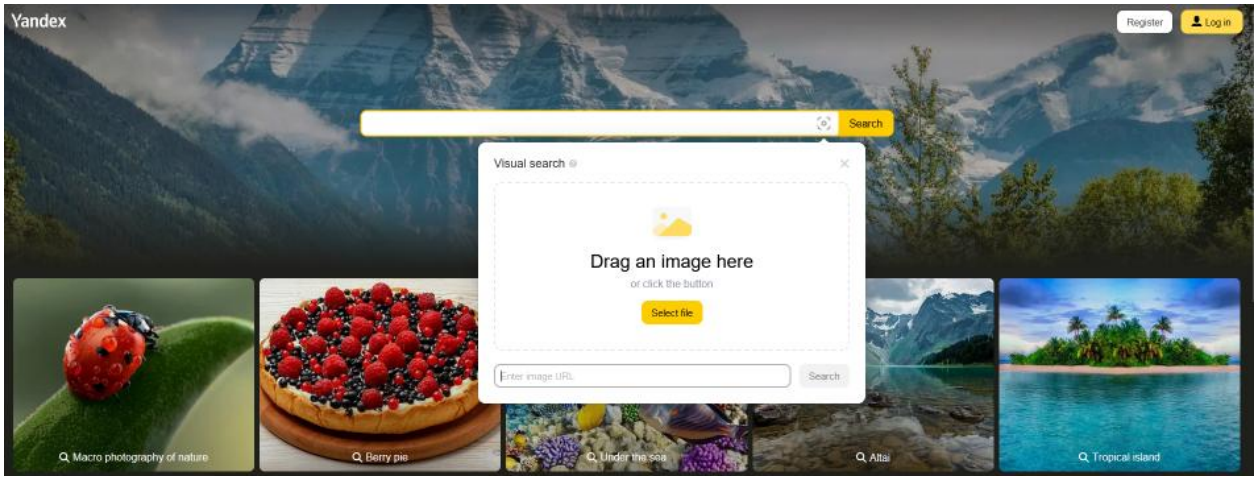


Imagen 113. Página principal de Yandex Images

Procedemos a utilizar el mismo ejemplo de Google Images pero utilizando Yandex Images. Tal como vemos en la Imagen 114, los resultados que ofrece Yandex son agrupados por secciones tal como hace Google. Dichas secciones son: tamaños adicionales de la misma imagen, imágenes visualmente similares y resultados donde se muestran imágenes similares en los sitios webs detectados.

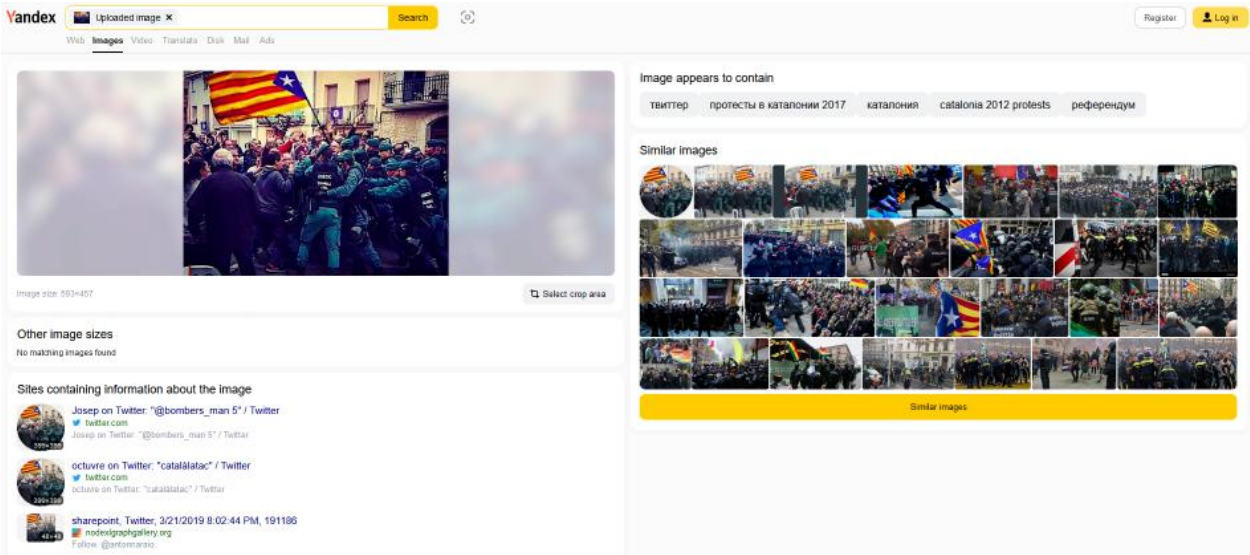


Imagen 114. Resultados ofrecido por Yandex Images

3.3.4. TINEYE

TinEye es un buscador de imágenes inversas, en el que originalmente servía para localizar otros tamaños que pudiera tener una imagen, pero en los últimos años ha evolucionado hasta tal punto que ahora es capaz de identificar imágenes similares visualmente. La potencia de TinEye radica en la detección de logos de cualquier índole y avatares de usuarios. El enlace de acceso a dicho servicio es el siguiente: https://tineye.com.

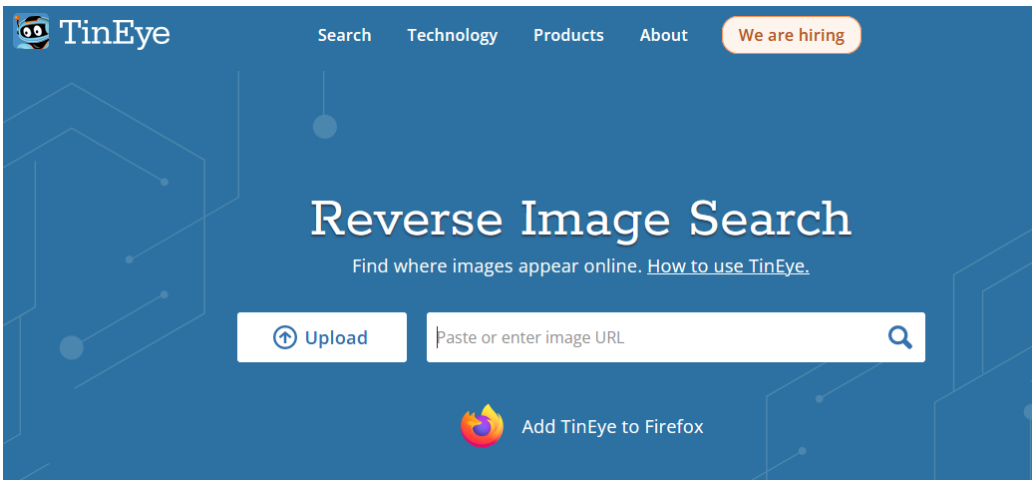


Imagen 115. Página principal de TinEye

Procedemos a utilizar el mismo ejemplo de Google Images pero utilizando TinEye. Tal como vemos en la Imagen 116, el buscador ha detectado un total de 164 resultados en el que podemos ir viendo la fecha de cuando ha sido encontrada por primera vez, lo que nos permite ir verificando por una línea de tiempo cada una de las imágenes detectadas en las diversas evidencias.

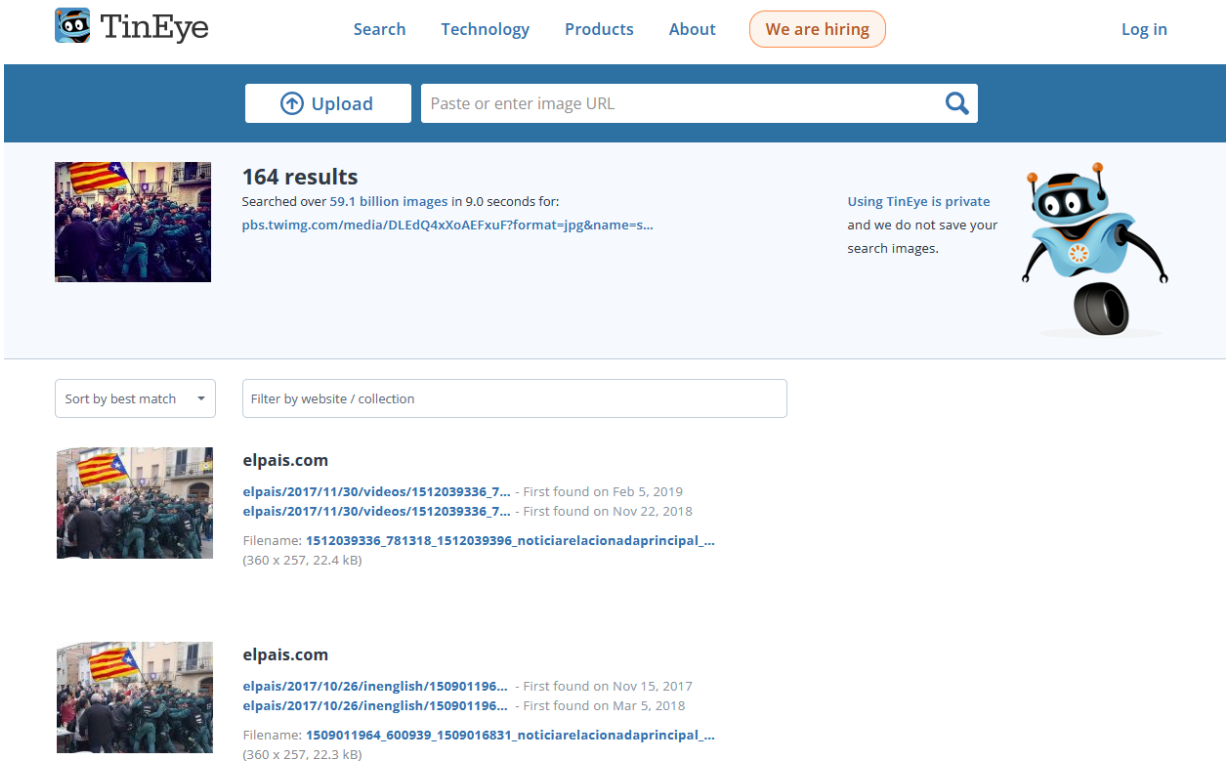


Imagen 116. Resultado de búsqueda obtenidos por TinEye

3.4. OTROS TIPOS DE BUSCADORES

Se disponen de otros tipos de buscadores como pueden ser Archive para localizar históricos de páginas webs o bien buscadores de FTP abierto y accesibles públicamente.

3.4.1. WAYBACK MACHINE

Wayback Machine es un buscador de histórico web que permite realizar búsquedas de

páginas webs y de usuarios de redes sociales para visualizar el contenido cacheado en su base de datos. Wayback Machine está alojado dentro del sitio web https://archive.org. Se trata de un buscador que va almacenando en sus base de datos diferentes screenshot de las páginas webs (incluidos sus enlaces internos) categorizados por fecha y hora, permitiendo navegar por los diferentes sitios web en distintas líneas de tiempo.

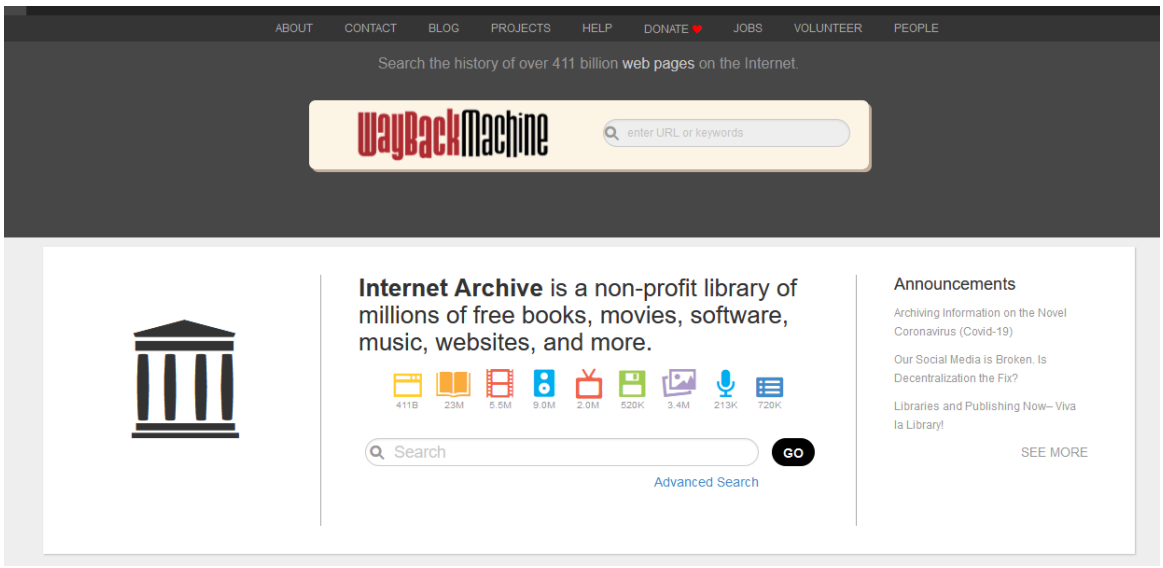
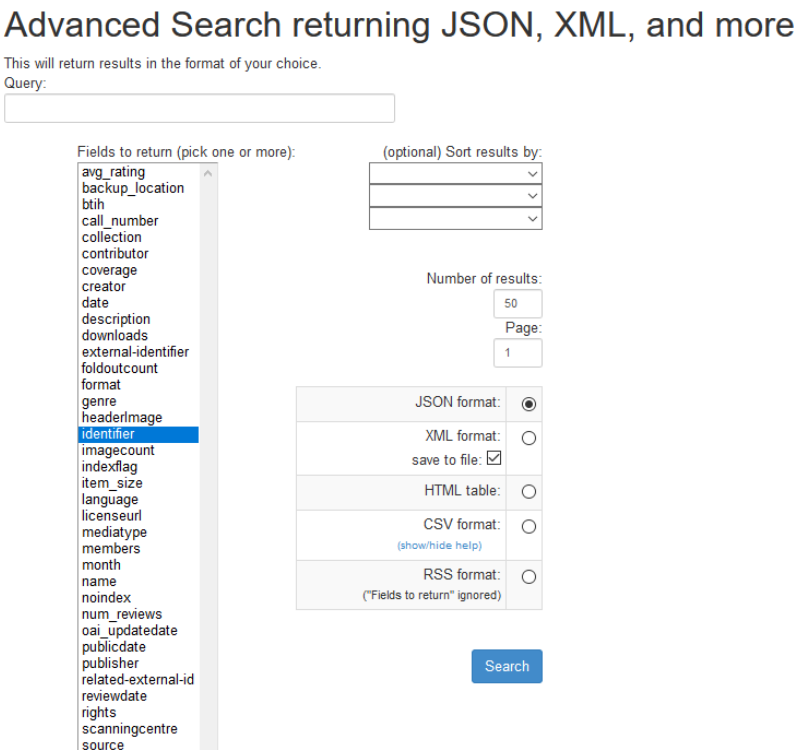


Imagen 117. Página principal de archive.org

Wayback Machine dispone de múltiples filtros de búsqueda avanzados totalmente personalizables, tal como se pueden ver en las imágenes 118 y 119.



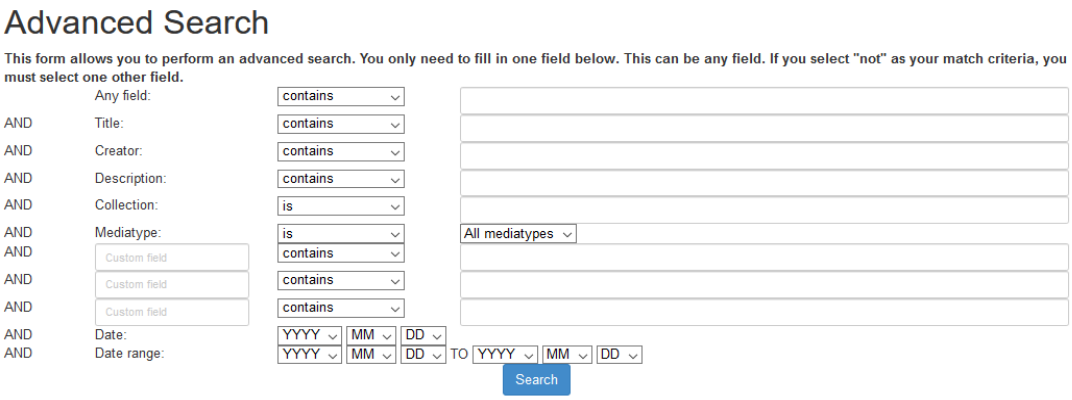


Imagen 119. Filtrado avanzado de Wayback Machine

Realizando una búsqueda del sitio web de marca.com (ver Imagen 120) podemos ver la línea de tiempo de los screenshot creados y la volumetría generada sobre dicha web.

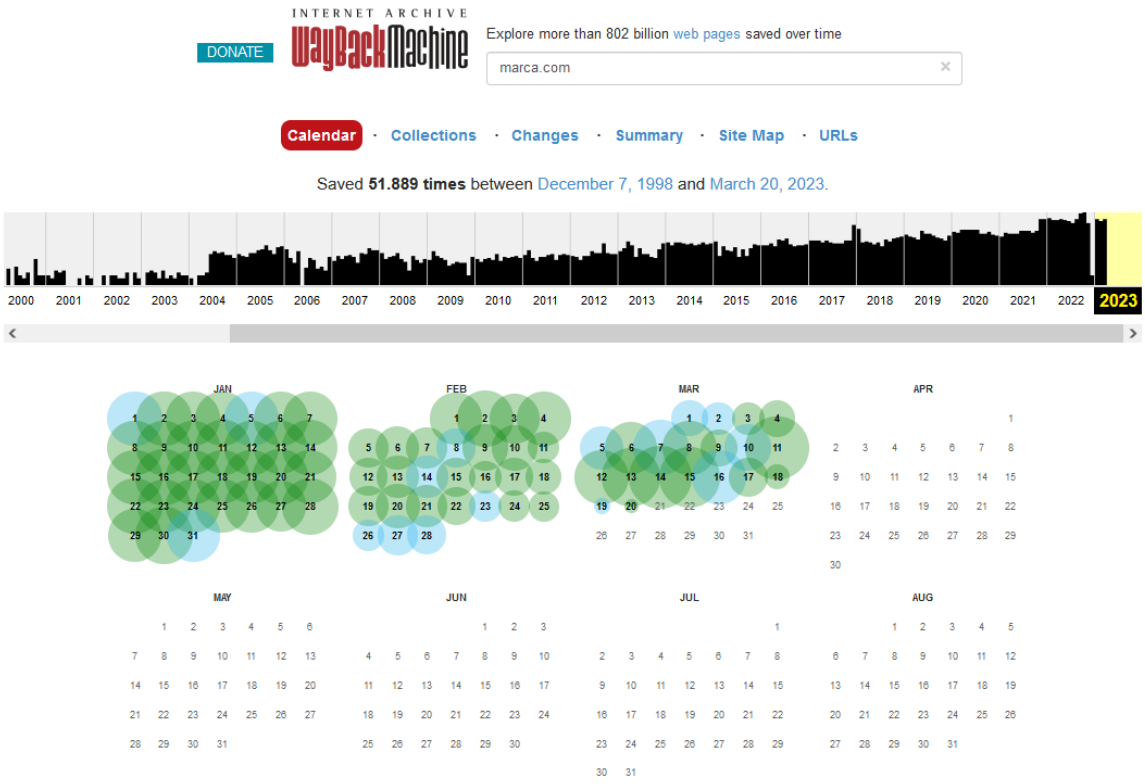


Imagen 120. Histórico de screenshots de marca.com

3.4.2. BUSCADORES DE FTP

Otro tipo de buscadores que tenemos a nuestra disposición son los centrados en FTP, recursos abiertos y públicos en los que podemos acceder sin ningún tipo de barrera de seguridad. Disponemos de tres tipos de buscadores de FTP siendo los siguientes:

- **NAPALM FTP**. Se trata de un servicio web que permite identificar información por medio de FTPs que estén abiertos en Internet, recogiendo en la actualidad **2.227 servidores** con **5.249 TB de información**. Como datos curiosos, muestra la fecha en la que los datos fueron vistos por última vez y dispone de copias cacheadas en el caso de que el origen deje de ser accesible. El enlace de acceso a dicho servicio es el siguiente: https://www.searchftps.net.

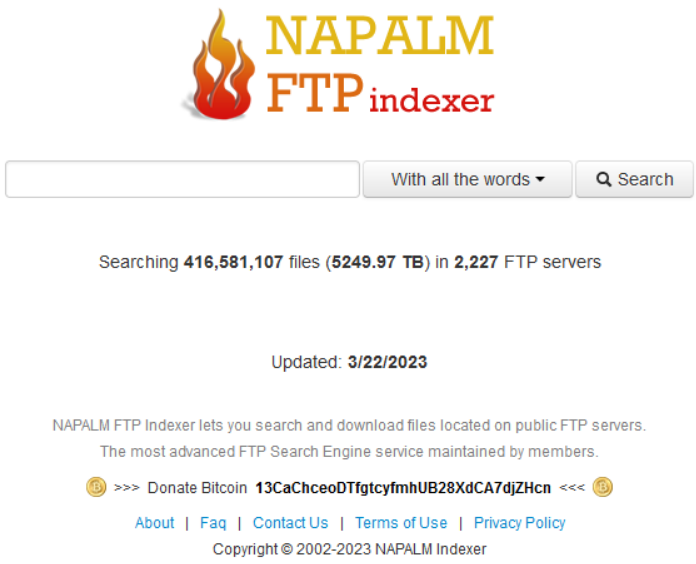


Imagen 121. Página principal de NAPALM FTP

- **MAMOHT**. Se trata de un servicio web ruso que permite identificar información a partir de FTPs que estén abiertos en Internet. Permite aislar la búsqueda por el país que aloja la información. En la Imagen 122 puede verse el sitio web de

MAMOHT y en la Imagen 123 un índice directo donde poder buscar y localizar la información. El enlace de acceso al sitio web es https://www.mmnt.ru y el enlace web del índice mencionado es https://www.mmnt.net.

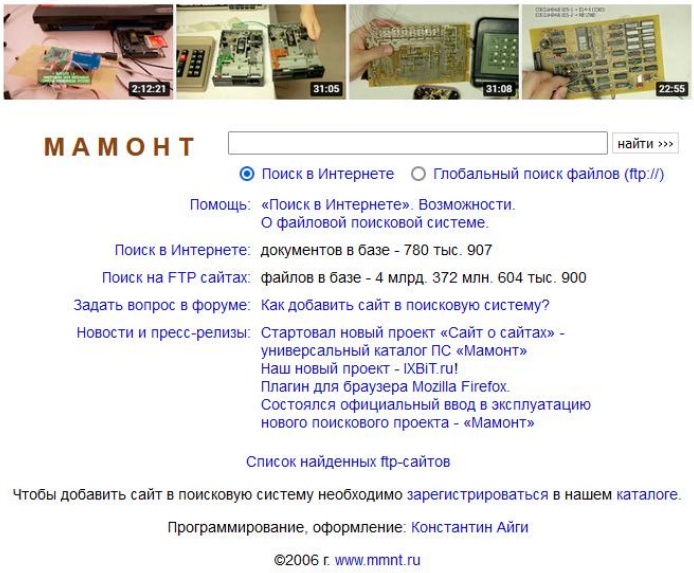
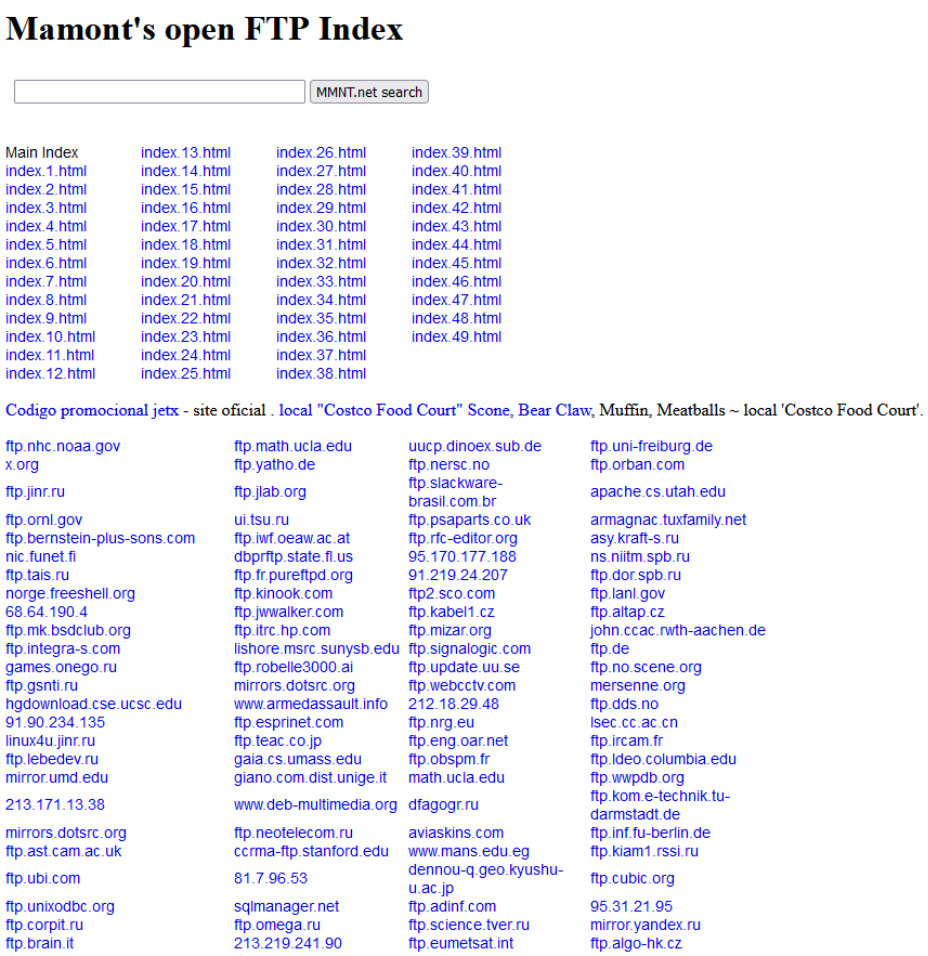


Imagen 122. Sitio web de MAMOHT



Mamont's open FTP Index

MMNT.net search

Main Index	index.13.html	index.26.html	index.39.html
index.1.html	index.14.html	index.27.html	index.40.html
index.2.html	index.15.html	index.28.html	index.41.html
index.3.html	index.16.html	index.29.html	index.42.html
index.4.html	index.17.html	index.30.html	index.43.html
index.5.html	index.18.html	index.31.html	index.44.html
index.6.html	index.19.html	index.32.html	index.45.html
index.7.html	index.20.html	index.33.html	index.46.html
index.8.html	index.21.html	index.34.html	index.47.html
index.9.html	index.22.html	index.35.html	index.48.html
index.10.html	index.23.html	index.36.html	index.49.html
index.11.html	index.24.html	index.37.html	
index.12.html	index.25.html	index.38.html	

Codigo promocional jetx - site oficial . local "Costco Food Court" Scone, Bear Claw, Muffin, Meatballs ~ local 'Costco Food Court'.

ftp.nhc.noaa.gov	ftp.math.ucla.edu	uucp.dinoex.sub.de	ftp.uni-freiburg.de
x.org	ftp.yatho.de	ftp.nersc.no	ftp.orban.com
ftp.jinr.ru	ftp.jlab.org	ftp.slackware-brasil.com.br	apache.cs.utah.edu
ftp.ornl.gov	ui.tsu.ru	ftp.psaparts.co.uk	armagnac.tuxfamily.net
ftp.bernstein-plus-sons.com	ftp.iwf.oeaw.ac.at	ftp.rfc-editor.org	asy.kraft-s.ru
nic.funet.fi	dbprftp.state.fl.us	95.170.177.188	ns.niitm.spb.ru
ftp.tais.ru	ftp.fr.pureftpd.org	91.219.24.207	ftp.dor.spb.ru
norge.freeshell.org	ftp.kinook.com	ftp2.sco.com	ftp.lanl.gov
68.64.190.4	ftp.jwwalker.com	ftp.kabel1.cz	ftp.altap.cz
ftp.mk.bsdclub.org	ftp.itrc.hp.com	ftp.mizar.org	john.ccac.rwth-aachen.de
ftp.integra-s.com	lishore.msrc.sunysb.edu	ftp.signalogic.com	ftp.de
games.onego.ru	ftp.robelle3000.ai	ftp.update.uu.se	ftp.no.scene.org
ftp.gsnti.ru	mirrors.dotsrc.org	ftp.webcctv.com	mersenne.org
hgdownload.cse.ucsc.edu	www.armedassault.info	212.18.29.48	ftp.dds.no
91.90.234.135	ftp.esprinet.com	ftp.nrg.eu	lsec.cc.ac.cn
linux4u.jinr.ru	ftp.teac.co.jp	ftp.eng.oar.net	ftp.ircam.fr
ftp.lebedev.ru	gaia.cs.umass.edu	ftp.obspm.fr	ftp.ldeo.columbia.edu
mirror.umd.edu	giano.com.dist.unige.it	math.ucla.edu	ftp.wwpdb.org
213.171.13.38	www.deb-multimedia.org	dfagogr.ru	ftp.kom.e-technik.tu-darmstadt.de
mirrors.dotsrc.org	ftp.neotelecom.ru	aviaskins.com	ftp.inf.fu-berlin.de
ftp.ast.cam.ac.uk	ccrma-ftp.stanford.edu	www.mans.edu.eg	ftp.kiam1.rssi.ru
ftp.ubi.com	81.7.96.53	dennou-q.geo.kyushu-u.ac.jp	ftp.cubic.org
ftp.unixodbc.org	sqlmanager.net	ftp.adinf.com	95.31.21.95
ftp.corpit.ru	ftp.omega.ru	ftp.science.tver.ru	mirror.yandex.ru
ftp.brain.it	213.219.241.90	ftp.eumetsat.int	ftp.algo-hk.cz

Imagen 123. Índice de MAMOTH